2021 年全国大学生信息安全竞赛

作品报告

作品名称： Logistics Trust：基于国产密码的零信任物流服务平台

电子邮箱： 1139317689@qq.com

提交日期： 2021 年 6 月 5 日

填写说明

1. 所有参赛项目必须为一个基本完整的设计。作品报告书旨在能够清晰准确地阐述（或图示）该参赛队的参赛项目（或方案）。

2. 作品报告采用A4纸撰写。除标题外，所有内容必需为宋体、小四号字、1.5倍行距。

3. 作品报告中各项目说明文字部分仅供参考，作品报告书撰写完毕后，请删除所有说明文字。(本页不删除)

4. 作品报告模板里已经列的内容仅供参考，作者可以在此基础上增加内容或对文档结构进行微调。

5. 为保证网评的公平、公正，作品报告中应避免出现作者所在学校、院系和指导教师等泄露身份的信息。

目　　录

摘要 1
第一章 作品概述 2
第二章 作品设计与实现 14
第三章 作品测试与分析 36
第四章 创新性说明 65
第五章 总结 66
参考文献 67

摘要

大数据、云计算等新一代信息技术的应用使传统物流行业向智能化、数字化转型，提高了物流供应效率，实现了信息的实时共享。数字化在为物流企业提质降本增效的同时，也为企业带来了新的安全挑战，传统安全防护机制遭遇瓶颈，网络安全边界逐渐瓦解，内外部威胁愈演愈烈，探索如何保障物流隐私信息的安全具有重要意义。针对当前物流体系存在的数据安全、数据访问权限分配不合理、安全边界消失、隐私保护缺失等问题，设计实现了一种基于国产密码的零信任物流服务平台。利用北斗卫星导航定位系统实现货物的高精度定位，方便用户查看货物的实时位置和运送轨迹；以国产密码算法为主体，采用SDP架构搭建零信任安全体系，精准控制网络边界访问行为；使用国产联盟链FISCO BCOS作为系统的区块链底层平台，实现交易信息的可追溯和交易各方的不可否认。与传统的基于边界的集中式物流系统相比，本系统以身份为中心，构建新的安全边界，保护用户隐私，助力物流企业数字化转型。

第一章 作品概述

1.1 研究背景

随着互联网时代的到来和电子商务的发展，中国物流业得到了快速发展，物流行业已成为我国经济的一匹黑马，中国也已经成为全球有重要影响力的物流大国和全球最大的物流市场。2020 年 1-8 月，全国物流服务企业业务量累计完成 480.5 亿件，同比增长 25.4%；物流业务收入累计完成 5274.5 亿元，同比增长 4.1%。在突如其来的新冠疫情下，中国物流行业充当了疫情中的逆行者，用科技助力无接触配送，为抗疫提供可靠的后勤保障。物流业推动和加速了国民经济的发展，在国民经济中处于战略性基础产业地位。

2019 年 10 月中共中央政治局第十八次集体学习中，中共中央总书记习近平在主持学习时强调，区块链技术的集成应用在新的技术革新和产业变革中起着重要作用，要把区块链作为核心技术自主创新的重要突破口，加快推动区块链技术和产业创新发展。2020 年 10 月，党的十九届五中全会顺利在北京召开，强调了加快发展数字经济，推进数字产业化和产业数字化，培育壮大区块链等新兴数字产业。2021 年 3 月 13 日，《中华人民共和国国民经济和社会发展第十四个五年规划和 2035 年远景目标纲要》（以下简称“十四五”规划纲要）正式对外公布。在区块链产业具体内容上，“十四五”规划纲要指出，推动智能合约、共识算法、加密算法、分布式系统等区块链技术创新，以联盟链为重点发展区块链服务平台和金融科技、供应链管理、政务服务等领域应用方案，完善监管机制。

近年来，物联网、人工智能、大数据、云计算等新一代智能技术与实体经济加速融合，物流业数字化转型迎来发展新的浪潮，降低了物流供应成本，实现了信息的实时共享，提升了各端的沟通。但物流行业数字化的同时，物流隐私信息的安全也带来了新的挑战。一旦物流系统被攻击，用户信息数据被泄露，不仅会给用户造成财政损失和人身安全问题，甚至危及公众和社会的安全。近年来，我国已发生多起物流信息安全事件，个人信息安全受到严重威胁。2019 年 7 月，韵达快递被通报公开收集个人信息规则，无隐私政策。2020 年 11 月，不法分子与圆通快递多位“内鬼”勾结，通过有偿租用圆通员工系统账号盗取公民个人信息，再层层倒卖公民个人信息至不同下

游犯罪人员，导致 40 万公民个人信息被泄露。

频发的信息泄露事件，让物流行业信息安全问题得到了社会前所未有的关注。物流信息安全成为物流行业面临的重要问题，突出表现在以下方面：

（1）隐私信息在传输过程中的安全问题。在当前的物流系统中，用户隐私信息没有在安全的环境下进行传输，一旦这些信息被截获将会给用户带来极大的安全隐患。

（2）隐私信息的存储安全问题。传统物流系统的信息大多记录在中心化的仓储管理系统 WMS 中，无法保证第三方的可信性，也很难杜绝用户隐私数据的非法修改和丢失，存在数据溯源困难和不可信等问题。

（3）隐私信息访问权限的不合理分配问题。当一个角色获得了多余隐私数据时，就存在着隐私数据泄露的风险。目前已发生多起物流公司内部员工泄露用户隐私信息的事件，这些数据一旦泄露到不法分子手中，将会对用户乃至整个社会造成极大的威胁。

（4）安全边界消失问题。产业数字化为企业网络基础设施带来了极大的复杂性，安全边界逐渐模糊，传统的基于边界的网络安全架构和解决方案难以适应现代企业网络基础设施。目前物流业已发生多起内部业务非授权访问，雇员与外部人员勾结进行有意的数据窃取的重大信息安全事件。

（5）隐私信息保护措施缺失问题。包括顺丰、申通、中通在内的多家国内物流巨头均可在网页上直接通过快递单号查询该包裹运送过程中的所有信息，攻击者甚至无需进行登录和身份验证。

在此背景下，针对当前频发的物流行业用户隐私泄露问题，本文提出并实现了一种基于国产密码的零信任物流服务平台，通过北斗高精度定位、国产密码算法、零信任安全、区块链等新一代信息技术，保障数据在传输、存储等过程中的安全，构建零信任安全体系，完整记录物流过程中的交易，保护用户隐私，提升用户物流体验。

1.2 研究意义

互联网的进步和电子商务的发展加速了中国物流行业的发展，我国也已成为全球最大的物流市场。线上购物已成为了人们生活的常态，我们每个人都是物流体系中的重要一环。物流业向智能化、数字化的转型，提高了物流配送的效率，提升了用户的物流体验。但层出不穷的信息泄露事件使得用户、企业甚至整个社会信息安全面临严

峻挑战，为了促进物流行业的再发展，并充分保护用户隐私，必须解决物流行业信息泄露问题。

基于国产密码的零信任物流服务平台保障了隐私数据在传输、存储等过程中的安全，能有效应对传统的基于边界的网络安全架构的安全痛点，动态评估不同角色的信用等级并授予不同的访问权限，记录物流过程中的交易并实现可追溯。本系统旨在对我国物流行业信息安全研究现状和问题分析的前提下，基于国产密码算法，采用零信任架构、区块链等技术实现各环节用户的隐私保护，期冀能够为适应物流业数字化转型需求的新一代安全体系和方案架构提供一些有价值的参考。

1.3 相关工作

1.3.1 北斗定位技术

（1）北斗导航定位系统概述

北斗卫星导航定位系统是我国鉴于国家安全和社会发展需要，自主设计，独立研发的导航定位系统，是为全球用户提供全天候、全天时、全方位的高精度定位、导航和授时服务的国家重要时空基础设施。经过北斗一号系统和北斗二号系统的建设，2020 年 6 月 23 日，随着北斗系统第五十五颗导航卫星（暨北斗三号最后一颗全球组网卫星）在西昌卫星发射中心成功点火发射，北斗三号全球卫星导航系统星座部署比原计划提前半年全面完成。

北斗导航系统定位系统由空间段、地面段和用户段构成。相比于其他卫星导航定位系统，北斗系统具有以下特点：一是北斗系统空间段采用三种轨道卫星组成的混合星座，与其他卫星导航系统相比高轨卫星更多，抗遮挡能力强，尤其低纬度地区性能特点更为明显。二是北斗系统提供多个频点的导航信号，能够通过多频信号组合使用等方式提高服务精度。三是北斗系统创新融合了导航与通信能力，具有实时导航、快速定位、精确授时、位置报告和短报文通信服务五大功能。

（2）北斗卫星定位技术

北斗卫星导航系统，采用有源和无源两种定位方式。有源定位即用户机需向地面控制中心发送位置请求，再由地面控制中心测算得到用户位置信息并将结构反馈到用户机。无源定位则无需用户机向地面控制中心发送请求，用户机对来自卫星信号进行

接收处理，从而计算出自身的位置信息。

无源定位的实质就是伪距测量。伪距是指卫星信号发出到用户机接收到信号的时间乘以光速所得到的距离，用户机同时接收来自四颗卫星的导航信号，通过时差测量获得用户机到四颗卫星的伪距，同时利用已知用户高程信息，计算出用户位置信息，无需地面控制中心参与计算。原理如图 1.1 所示。

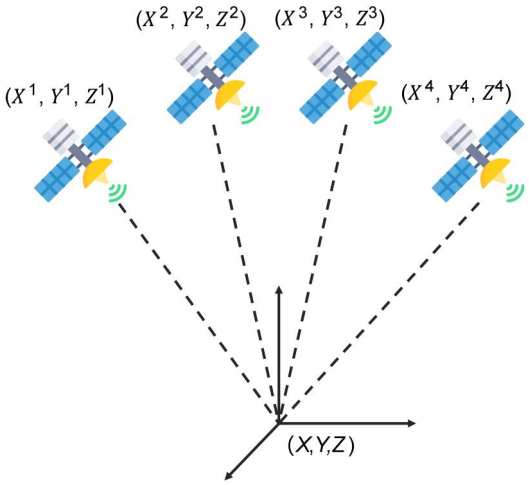


图1.1 北斗定位原理图

已知四颗北斗卫星在空间中的坐标分别为$(X^1,Y^1,Z^1),(X^2,Y^2,Z^2),(X^3,Y^3,Z^3),(X^4,Y^4,Z^4)$，到用户机的距离分别为$R_1$，$R_2$，$R_3$，$R_4$，卫星向用户机发送信号的时刻为$t_s^1$，$t_s^2$，$t_s^3$，$t_s^4$。由于卫星载钟是原子钟，而用户机一般搭载的是石英钟，两者精度不同，为确保定位精度，设接收机与原子钟时钟差为dt_r。则可列出如下方程求得用户机坐标(X,Y,Z)与时钟差dt_r。

$$\begin{cases} R_1 = c(t_r + dt_r - t_s^1) = \sqrt{(X^1 - X)^2 + (Y^1 - Y)^2 + (Z^1 - Z)^2} \\ R_2 = c(t_r + dt_r - t_s^2) = \sqrt{(X^2 - X)^2 + (Y^2 - Y)^2 + (Z^2 - Z)^2} \\ R_3 = c(t_r + dt_r - t_s^3) = \sqrt{(X^3 - X)^2 + (Y^3 - Y)^2 + (Z^3 - Z)^2} \\ R_4 = c(t_r + dt_r - t_s^4) = \sqrt{(X^4 - X)^2 + (Y^4 - Y)^2 + (Z^4 - Z)^2} \end{cases}$$

1.3.2 国密算法

国密算法是指国家密码局认定的国产密码算法，是国家商用密码管理办公室从国家信息安全的角度出发，制定的一系列国家商用密码算法标准。可分为对称加密算法、非对称加密算法和散列算法 3 类。具体包括 SM1，SM2，SM3，SM4，SM7，SM9，祖

冲之密码算法等。本节重点介绍系统采用的 SM2，SM3，SM4。

（1）对称密码算法

SM4 分组密码算法是我国自主设计的分组对称密码算法，用于实现数据的加解密运算，以保证数据和信息的机密性。SM4 的加密算法和密钥扩展算法是公开的，其分组长度和密钥长度均为 128 位。SM4 采用以字为单位进行加密运算，一次迭代运算就是一轮变换，共进行 32 轮。每轮的过程如下：每次将第$i+1$个字、第$i+2$个字、第$i+3$个字和轮密钥（由加密密钥通过密钥扩展算法实现）进行异或操作，然后对操作的结果进行合成置换。合成置换由非线性变换和线性变换复合而成。非线性变换由 4 个并行的 S 盒构成，非线性变换的输出是线性变换的输入。合成置换的结果和第i个字进行异或操作，并作为第$i+4$个字。解密算法的结构和加密算法相同，只是轮密钥的使用顺序相反。要保证一个对称密码算法的安全性的基本条件是其具备足够的密钥长度，SM4 算法与 AES 算法具有相同的密钥长度 128 比特，因此在安全性上高于 3DES 算法。

（2）非对称密码算法

SM2 算法是国家密码管理局于 2010 年发布的椭圆曲线公钥密码算法，包括 SM2-1 椭圆曲线数字签名算法，SM2-2 椭圆曲线密钥交换协议，SM2-3 椭圆曲线公钥加密算法。相较于著名的公钥密码算法 RSA 算法，SM2 算法更加先进安全，在我国商业密码体系中被用来替换 RSA 算法。

ECC 椭圆曲线密码体制由 Koblitz 和 Miller 在 1985 年各自引入密码学。椭圆曲线的 Weierstrass 方程为：

$$y^2 + a_1xy + a_3y = x^3 + a_2x^2 + a_4x + a_6$$

其中，上面的所有点和无穷远点构成一个加法交换群，其中无穷远点是加法零元。此群的加法法则可以由弦切法所给出。由弦切法便可以给出椭圆曲线上的加法方程。多倍点运算是指：给定一点P和一个整数k计算kP，即k个P点的和。椭圆曲线上的离散对数问题为：给定点P和kP，计算整数k。椭圆曲线密码体制的安全性便是建立在椭圆曲线离散对数问题之上。

SM2 标准包括总则、数字签名算法、密钥交换协议、公钥加密算法 4 个部分。SM2 算法主要考虑素域F_p和F_{2^m}的椭圆曲线，分别介绍了这两类域的表示、运算以及

域上的椭圆曲线的点的表示，运算和多倍点计算算法。然后介绍了编程语言中的数据转换，包括整数和字节串、字节串和比特串、域元素和比特串、域元素和整数、点和字节串之间的数据转换规则。详细说明了有限域上椭圆曲线的参数生成以及验证，椭圆曲线的参数包括有限域的选取、椭圆曲线方程参数、椭圆曲线群基点的选取等，并给出了选取的标准以便于验证。最后给出椭圆曲线上密钥对的生成以及公钥的验证，用户的密钥对为(s,sP)，其中s为用户的私钥sP，为用户的公钥，由于离散对数问题从sP难以得到s，并针对素域和二元扩域给出了密钥对生成细节和验证方式。

数字签名算法适用于商用应用中的数字签名和验证，可满足多种密码应用中的身份认证和数据完整性、真实性的安全需求。密钥交换协议适用于商用密码应用中的密钥交换，可满足通信双方经过两次或可选 3 次信息传递过程，计算获取一个由双方共同决定的共享秘密密钥（会话密钥）。公钥加密算法适用于国家商用密码应用中的消息加解密，消息发送者可以利用接收者的公钥对消息进行加密，接收者用对应的私钥进行解密，获取消息。基于 SM2 的数字签名算法、密钥交换协议以及公钥加密算法都使用了国家密管理局批准的 SM3 密码杂凑算法和随机数发生器。

（3）散列算法

SM3 算法是目前国家商用密码算法标准中唯一的散列算法，可应用于数字签名及验证、生成随机数、生成消息认证码等，其算法公开。SM3 对输入长度小于2^{64} bit 的消息，经过填充和迭代压缩，生成长度为 256bit 的散列值，其中使用了异或、模、模加、移位、与、或、非运算，由填充、迭代过程、消息扩展和压缩函数所构成。SM3 算法的压缩函数与 SHA-256 的压缩函数具有相似的结构，据国家安全局表示，其安全性及效率与 SHA-256 相当。

1.3.3 零信任架构

近些年来，以零信任为代表的新一代网络安全理念不断衍生和应用，打破了网络位置和信任间的潜在默认关系。为最大限度保证资源被可信访问，提升企业 IT 架构安全性，零信任的安全理念为“永不信任，持续验证”。默认情况下，企业内外部的任何人、事、物均不可信，应在授权前对任何试图接入网络和访问网络资源的人、事、物进行验证。

（1）零信任基本原则

默认一切参与因素不受信：零信任的信任关系源自于对所有参与对象和行为的动态验证，所有参与对象和行为共同构成一次端到端的资源访问，这些参与对象包括网络、应用、终端、访问主体、数据、工作负载，行为包括访问请求、连接建立、策略下发等。零信任不为任何参与因素预制信任条件，所处位置无法决定信任关系。

最小权限原则：零信任强调资源按需分配，仅授予各行为所需的最小权限。对每个行为单独授权，对一种资源的授权不会自动作用于另一种资源的访问权限。

持续动态访问控制和授权：对资源的访问控制由动态授权策略决定，动态授权策略依据参与对象的主体信息和行为信息，通过对多源信息进行分析获得授权策略。一旦动态授权策略依据发生变化，将重新计算授权策略，这一动作将在一次端到端的资源访问的全生命周期中持续进行。

持续安全防护：确保进行资源访问的参与对象处于安全状态，通过安全产品/工具,及时发现安全问题，并采取措施降低安全风险。

（2）零信任安全逻辑架构

基于零信任基本原则，企业可建设或改造已有网络安全体系以实现零信任安全逻辑架构，利用零信任安全逻辑架构为 IT 系统提供持续的安全保障。架构如图 1.2 所示，由零信任核心逻辑组件和内部或外部数据源组成。

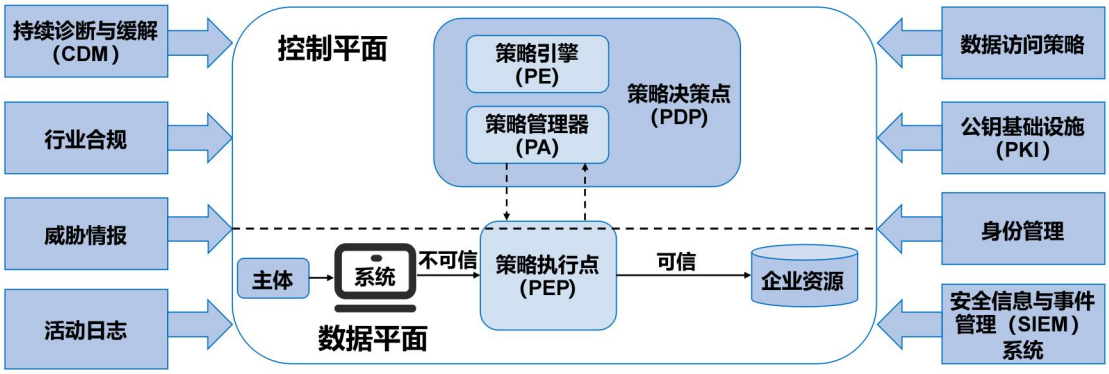


图 1.2 零信任安全逻辑架构

零信任安全逻辑架构对访问参与对象和访问资源之间的所有行为进行处理，零信任核心部分分为控制平面和数据平面。访问主体发起访问请求，由控制平面的策略引擎进行多源信任评估计算，由策略管理器对计算结果进行判定，决定授权策略，一旦授权访问，策略管理器将通知数据平面的策略执行点，为该次访问建立安全连接。此时策略引擎仍持续进行评估,一旦参与对象或其行为发生变化，策略引擎将依据新的评

估源进行信任评估，策略管理器随时依据评估结果判定授权策略是否需要改变，随时通知策略执行点执行相应操作，最大限度保障资源安全。

基于零信任安全逻辑架构核心逻辑组件主要包括三部分，：

策略引擎（Policy Engine, PE）：该组件负责信任评估，通过收集和分析参与对象和行为等多源信息，对访问主体进行持续的信任评估。

策略管理器（Policy Administrator, PA）：该组件作为策略控制点，依赖信任评估引擎的信任评估结果，持续判定授权策略。

策略执行点（Policy Enforcement Point, PEP）：该组件作为策略执行点，为授予权限的访问主体，建立其访问主体和被访问资源之间的安全通道。在实际架构中，该逻辑组件可能由两个不同的组件构成：客户端(如用户终端设备上的代理插件等)和资源侧网关(如 Web 网关、API 网关等)，或单个代理组件。

零信任逻辑架构除了核心逻辑组件，还包括内部和外部信任源，与策略引擎协同，将收集并分析参与对象和其行为的安全信息，传递给策略引擎协同，将收集并分析参与对象和其行为的安全信息，传递给策略引擎，为其进行信任评估提供依据。信任源包括：CDM（持续诊断与缓解）、行业行规、威胁情报、活动日志、数据访问策略、PKI（公钥基础设施）、身份管理、安全信息与事件管理（SIEM）系统。

1.3.4 区块链

区块链最初由研究人员于 1991 年揭示，旨在为数字文档添加时间戳，以便可追溯或难以篡改。2009 年，中本聪第一次将区块链应用于比特币金融体系的管理之中。区块链本质上是一个去中心化的数据库，通过共识算法来增添和修改数据，通过链式区块结构来检验和保存数据。区块链的核心是分布式账本、去中心化、智能合约和共识机制。除此之外，典型的区块链技术还具有可靠数据库、去信任、交易准匿名性、开源可编程的特点。

（1）分布式账本

如图 1.3 所示，区块链本质是可共享的分布式账本。分布式账本是一种在网络成员之间进行信息共享、信息复制和信息同步的数据库，交易记账由各个网络的参与者共同完成。其主要有两个特点：分布式、去中心化。

分布式：主要指将数据分散存储到多个地方。早期集中式的数据库，一旦这个数

据库发生问题，就会出现宕机、无法使用等严重后果，分布式数据存储很好地解决了这一问题。

去中心化：去中心化数据库中的每位参与者都有一份真实账本的副本，大家一起记录每笔交易，一起维护数据，每隔一定时间核对账本，一旦有谁篡改历史记录，立马就能被发现。此外，这个账本对每个人都完全开放，如果想参与进来，只要通过区块链网络的许可，就可以成为其中的一个节点。

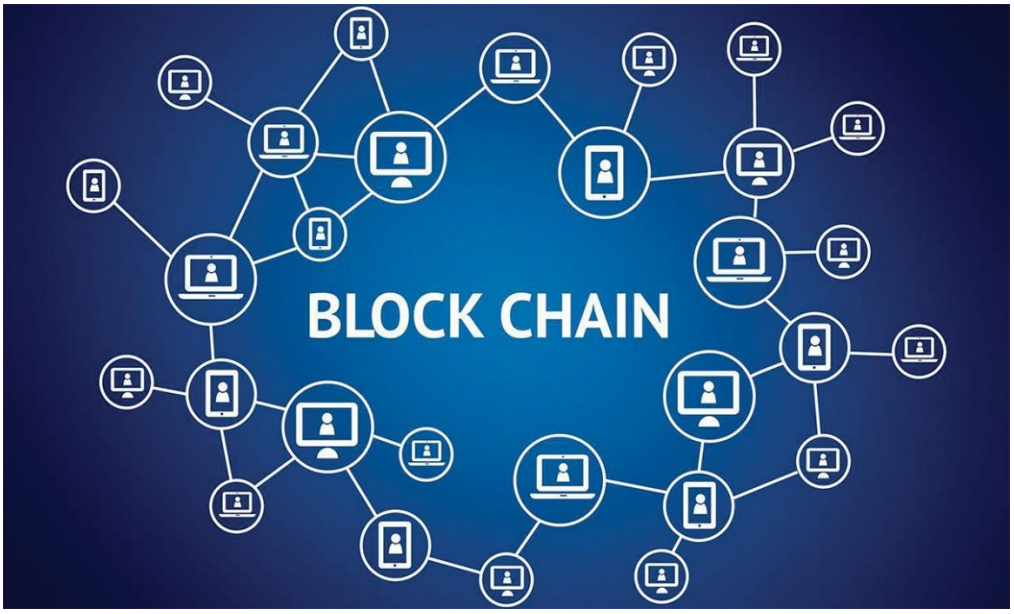


图 1.3 区块链

（2）共识机制

在分布式计算领域的早期研究中，为保证分布式集群中所有节点的数据完全相同并能对某个提案达成一致意见，提出了共识机制。通过借鉴分布式计算领域的共识研究，区块链采用共识机制使节点维持一致的区块链视图，实现系统稳定、可靠运行。共识算法的研究由来已久，可分为证明类、随机类、选举类、联盟类、混合类。Castro 等于 1999 年提出了实用拜占庭容错算法（Practical Byzantine Fault Tolerance，PBFT），PBFT 算法将 BFT 算法的复杂度从指数级降到了多项式级，使 PBFT 算法能够真正地在实际中应用。拜占庭容错算法的研究也让共识算法从解决传统的分布式数据一致问题进入到解决区块链共识的全新阶段。

区块链中的共识机制主要解决两个问题：**①区块数据写入：**各节点都独立维护一份区块链副本并拥有向区块链中写入数据的权利，为避免各自写入数据后节点保存的区块链不同而出现数据混乱的情况，需选择节点负责写入数据。**②区块同步：**当节点

写入数据后，其余节点能及时地同步更新数据。

（3）智能合约

智能合约就是执行合约条款的程序代码，在区块链技术中得到了长足的发展，以以太坊为代表的区块链将智能合约的应用推向了更高的水平。智能合约的概念最早由密码学家尼克萨博在 1994 年提出，用智能合约替代传统的纸质合约能够很大程度上减少在合约制定、执行效能和控制协议上的人工花费与计算成本。从安全的角度来说，首先智能合约同区块链数据一样拥有不可篡改、分布式、一致完整性等特点；其次，智能合约也作为一种保障区块链安全的技术手段。智能合约中规定了参与节点的权利和义务、触发合约执行的条件以及执行的对应结果，当智能合约被注入到区块链中之后，就不会受到任何一方的影响，以确保客观准确地执行，实现相应的功能。

（4）体系结构

目前有很多区块链框架，如比特币、以太坊、Hyperledger Fabric 和 FISCO BCOS 等。比特币、以太坊等当前已经投入生产运行中的主流区块链系统都以加密货币为核心，采用完全去中心化的设计，很难保证用户数据的隐私性。同时，为了保证在这种开放机制下的抗攻击性，比特币、以太坊等区块链系统使用了 PoW、PoS 等复杂共识机制来达到分布式系统内的一致性，并严格限制区块大小和出块速度，这也就导致了这些系统的吞吐量受限，且系统内每笔交易需要很长的确认时间。如果选用这样的区块链框架，将很难满足当前物流行业在数据吞吐量和交易即时性指标上的需求。

FISCO BCOS 是由国内企业主导研发、对外开源、安全可控的企业级金融联盟链底层平台，适用于广泛的分布式商业场景。同时，为了充分支持国产密码学算法，金链盟基于国产密码学标准，实现了国密加解密、签名、验签、哈希算法、国密 SSL 通信协议，并将其集成到 FISCO BCOS 平台中，实现了对国家密码局认定的商用密码的完全支持。因此经综合考虑，本系统采用 FISCO BCOS 作为区块链底层平台。FISCO BCOS 架构如图 1.4 所示。

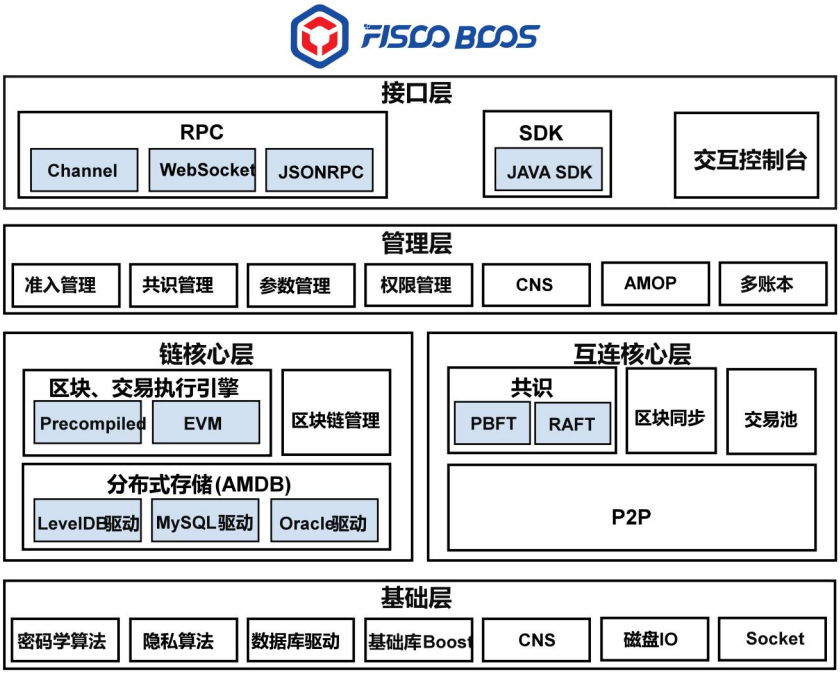


图 1.4 FISCO BCOS 整体架构

基础层：提供区块链的基础数据结构和算法库。

核心层：实现了区块链的核心逻辑，核心层分为链核心层和互连核心层。链核心层实现了区块链的链式数据结构、交易执行引擎和存储驱动。互联核心层实现了区块链的基础 P2P 网络通信、共识机制和区块同步机制。

管理层：实现区块链的管理功能，包括参数配置、账本管理和 AMOP。

接口层：面向区块链用户，提供多种协议的 RPC 接口、SDK 和交互式控制台。

1.4 主要研究内容

（1）利用**北斗卫星导航定位系统**精度高、快速定位、精确授时、抗遮挡能力强等特点，实现货物的高精度定位，方便用户查看货物的实时位置和运送轨迹，提升用户体验，也可以对北斗的民用推广带来一些助力。

（2）以**国密算法**为主体，通过 SM2、SM3、SM4 等多种国密算法，保证用户数据的安全性、完整性。并对现有技术和架构进行了国密改造，实现可控安全。

（3）构建**零信任安全体系**，采用 SDP 架构，建立新的网络安全边界，运用多因子认证，并持续评估参与者信用等级，在边界防护、通信传输、身份认证、数据保密等方面，进一步收窄系统暴露面，更细粒度地保障业务系统安全。

（4）利用**区块链技术**去中心化、防篡改、可追溯等特点，将物流过程中的所有

交易信息摘要存储在区块链上，实现物流交易信息的溯源以及交易各方的不可否认，有效保护用户隐私，提高物流可信力。同时，通过跨域管理加强了数据的流通性。

1.5 应用前景分析

对政府和社会而言，层出不穷的物流信息泄露问题造成了民众的隐私泄露和恐慌，造成了巨大的财产损失，危害了社会的健康发展。本文提出并实现了一种基于国产密码的零信任物流服务平台，能有效保护用户的隐私信息，提升物流业的可信力，创造良好的物流环境，促进物流行业数字化。同时该方案也是对发展区块链平台和智慧物流领域应用方案、加快数字产业化、北斗应用化的有效探讨。

对物流企业而言，本方案通过国密算法、零信任安全架构、区块链等多项安全技术，能有效防止企业数据和用户隐私的泄露和窃取。此外，物流过程中的交易信息与用户信用分数都将完整记录在区块链上，方便监管，一旦出现包裹纠纷问题，实现对物流交易信息的追根溯源。

对用户而言，该方案有效解决了当前物流体系的信息泄露问题，最大程度的降低了用户隐私泄露的风险，动态评估授予隐私信息访问的权限，避免用户的财产损失和保护用户的人身安全。除此之外，用户还可以准确获得货物的实时位置和运送轨迹，提升物流体验。

第二章 作品设计与实现

2.1 总体架构

本文采取 B/S 架构进行基于国产密码的零信任物流服务平台的设计。B/S 架构下，用户只需通过使用计算机设备安装的浏览器访问指定页面就可以进行业务的查看和操作。此外 B/S 模式系统开发、维护、升级方便，进行系统升级时，只需在服务器层面进行升级，用户只需对原有页面进行刷新或重新访问即可。

基于国产密码的零信任物流服务平台总体架构如图 2.1 所示，整个系统采用四层设计：用户业务层、数据处理和接口层、区块链网络层和基础支撑层。此外，整个系统根据零信任安全的思想进行了设计，将对物流系统中的每个用户不断的进行动态评估并授权。

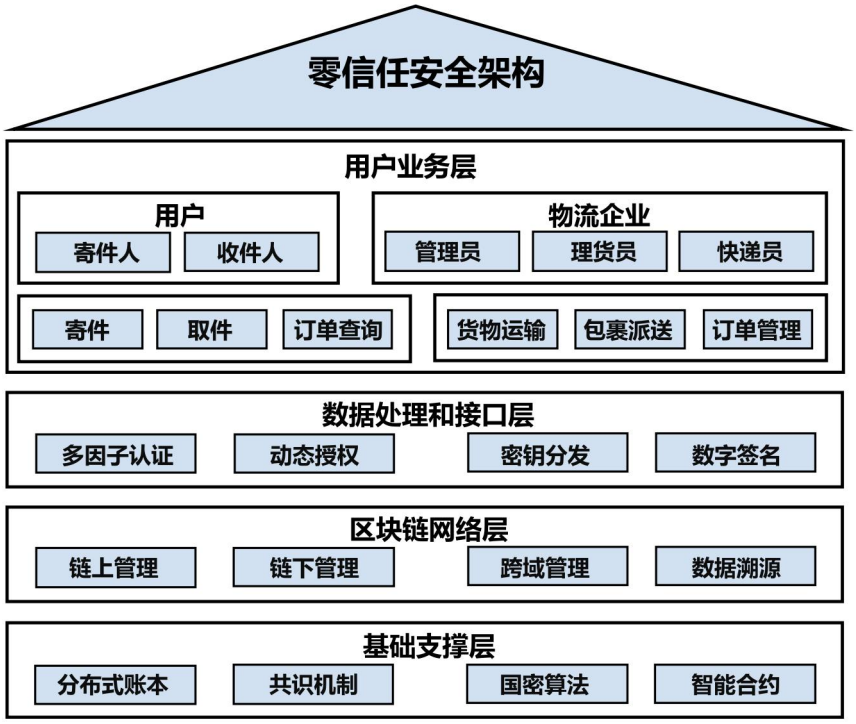


图 2.1 基于国产密码的零信任物流服务平台总体架构

用户业务层：通过 HTML、CSS、Vue.JS 等技术为用户构建一个方便易用、简洁美观的 web 客户端，传出用户输入的数据，接收系统服务器返回的结果数据并实时渲染，提供寄件、取件、订单查询、包裹派送和订单管理等操作。

数据处理和接口层：包含多因子认证、动态授权、密钥分发、数字签名等模块，

对不同角色的用户授予不同的权限，并对用户请求进行数据处理，是连接用户业务层和区块链网络层的桥梁。

区块链网络层：将系统中的所有数据及操作请求封装成标准的区块链交易形式，并对数据进行管理，实现区块链的基础 P2P 网络通信、共识机制和区块同步机制。

基础支撑层：实现了区块链的核心逻辑，是整个物流系统的核心，包括分布式账本、共识机制、国密算法和智能合约等模块，实现区块链的链式数据结构、交易执行引擎和存储驱动。

2.2 系统流程

图 2.2 展示了本系统整体流程。

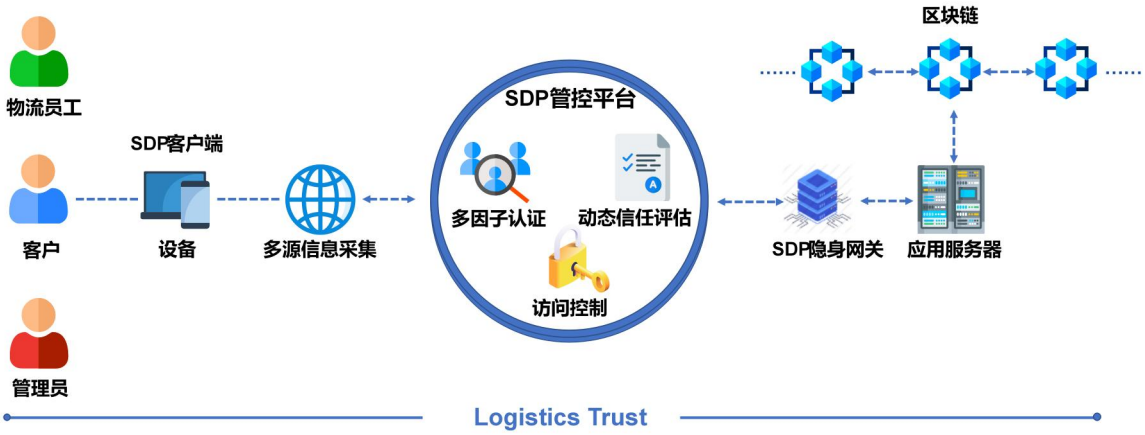


图 2.2 系统流程

详细阐述如下：

① 用户（客户、物流员工、管理员）通过安装在设备上的 SDP 客户端，使用单数据包授权（SPA）向 SDP 管控平台发出访问请求。

② SDP 管控平台在对用户进行多因子认证之前，需要对用户进行多源信息采集，包括用户身份、系统环境、用户动态行为等。

③ 多源信息采集结束后，多因子认证平台将对不同角色用户采集信息（用户身份、系统环境、用户动态行为）进行多因子的安全检验和认证。

④ 通过多因子认证的用户将由动态信任评估平台对用户业务请求进行解析、评估、决策，以确定用户的信任分数以及等级。且信任评估是持续的，伴随整个访问过程。

⑤ 在进行信任评估之后，访问控制平台对用户权限动态调整，保障物流场景下的动态信任授权体系。

⑥ SDP 管控平台返回隐身网关 IP 列表以及权限列表至 SDP 客户端。

⑦ SDP 客户端使用 SPA 技术并附带实时授权信息，向 SDP 隐身网关发出请求，SDP 隐身网关根据请求信息和安全策略进行验证和匹配，允许或拒绝用户的访问请求。

⑧ SDP 隐身网关为被允许的访问请求建立双向加密连接，客户端通过加密隧道访问企业应用服务或资源。

⑨ 每次订单完成后，都将会对物流过程中的参与人员进行信用评分，并以特定的数据形式记录在区块链上。同时存储在区块链上的还有物流相关信息。

2.3 功能模块

2.3.1 高精度定位模块

（1）位置信息获取

相较于传统的定位应用，基于北斗的高精度定位模块可以显著提高定位和授时精度，使终端的定位精度提高到米级以内，且定位精度分布均匀、实时性好、可靠性高。本文设计的高精度定位模块主要用于实现货物的定位功能，分为用户端和运输端两部分。用户端主要由北斗天线收发模块构成，用于发送申请和接收报文数据；运输端主要由北斗定位模块和北斗天线收发模块构成，用于获取位置信息以及返还报文数据。用户获取货物位置信息的过程如图 2.3 所示。

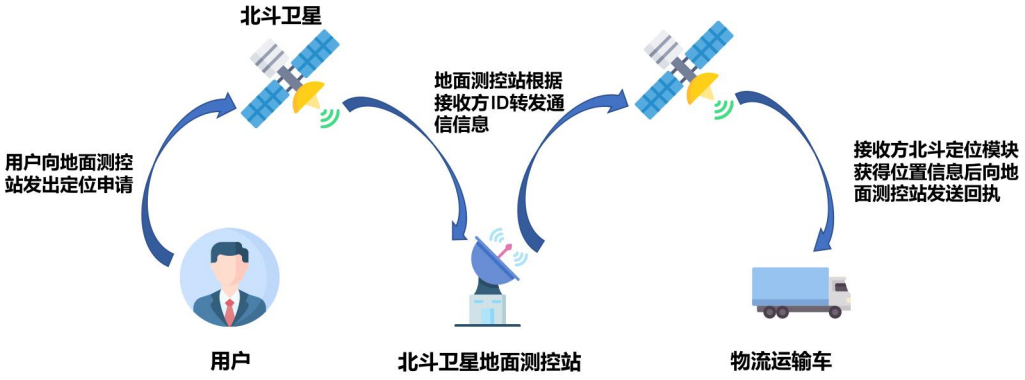


图 2.3 用户获取货物位置信息流程

北斗卫星导航定位系统采用双向短报文通信，每个北斗用户都拥有一个独属于自己的识别码（ID 号）。当用户发出定位申请指令时，地面测控中心通过调用串口所连

接的卫星天线收发器，根据接收方 ID 号转发加密处理后的通信报文。在收到定位申请后，物流运输车中的北斗定位模块会通过卫星获取自己的位置信息，并通过天线收发模块返还加密后的信息接收方 ID 号和位置信息。地面测控中心解密出接收方的地址和运输车位置信息，再将报文进行加密用卫星广播给用户，只有对应 ID 号的用户才能收到卫星广播的报文数据。

系统采用 ATGM336H-5N 系列模块，该模块支持北斗、GPS 双模块定位，是由中科微自主研发的六合一多模卫星导航模块，该模块性价比高，操作简单，具有高灵敏度、低功耗、低成本等优势，适合车载导航与定位。该模块将采集到的数据通过串口发送给中央处理单元，中央处理单元按照北斗短报文通信协议的格式进行处理、打包封装。本系统所用报文协议格式为$BDRMC，<1>，<2>，<3>，<4>，<5>，<6>，<7>，<8>，<9>，对应字段内容见表 2.1。

表 2.1 报文协议格式内容

字段	名称	说明
<1>	UTC 时间	hhmmss（时分秒）格式
<2>	定位状态	A=有效定位，V=无效定位
<3>	纬度	ddmm.mmmm（度分）格式
<4>	纬度半球	N（北半球）或 S（南半球）
<5>	经度	ddmm.mmmm（度分）格式
<6>	经度半球	E（东经）或 W（西经）
<7>	地面速率	000.0~999.9 节
<8>	地面航向	000.0~359.9 度，以真北为参考基准
<9>	UTC 日期	ddmmyy（日月年）格式

（2）位置信息可视化

为了方便用户查看货物的实时位置信息和运输轨迹，提升用户的物流体验，本系统采用百度地图 API 接口来实现货物位置信息的可视化。相较于其他的在线地图服务平台，百度地图提供的 API 接口模块化设计良好，支持各主流浏览器，文档完备，方便开发。

调用百度地图 API 接口首先需要申请密钥，申请网址为 http://lbsyun.baidu.com/apiconsole/key，应用类型选择浏览器端并启用所有服务，设置 Referer 白名单为*，即不对任何域名做限制，设置完毕后即可获得应用的密钥 AK。

实现位置信息可视化步骤如下：

① 引入 JavaScript API 文件，此时需使用自己申请的 API 密钥 AK：<script src="http://api.map.baidu.com/getscript?v=3.0&ak=qA9vU8qVyw3FbpMG2qobVhH0kYzock8u"></script>

② 在搜索图标上绑定用户点击事件，当用户输入货物单号并点击该图标后，即可通过 API 接口使用 get 请求获取数据库中指定订单号包裹的位置信息，并对页面进行实时渲染，显示该货物的位置信息及轨迹。

③ 用户仅需在订单查询页面输入想要查询的包裹单号，点击搜索按钮即可查看当前包裹所处的位置以及物流轨迹，如图 2.3 所示。

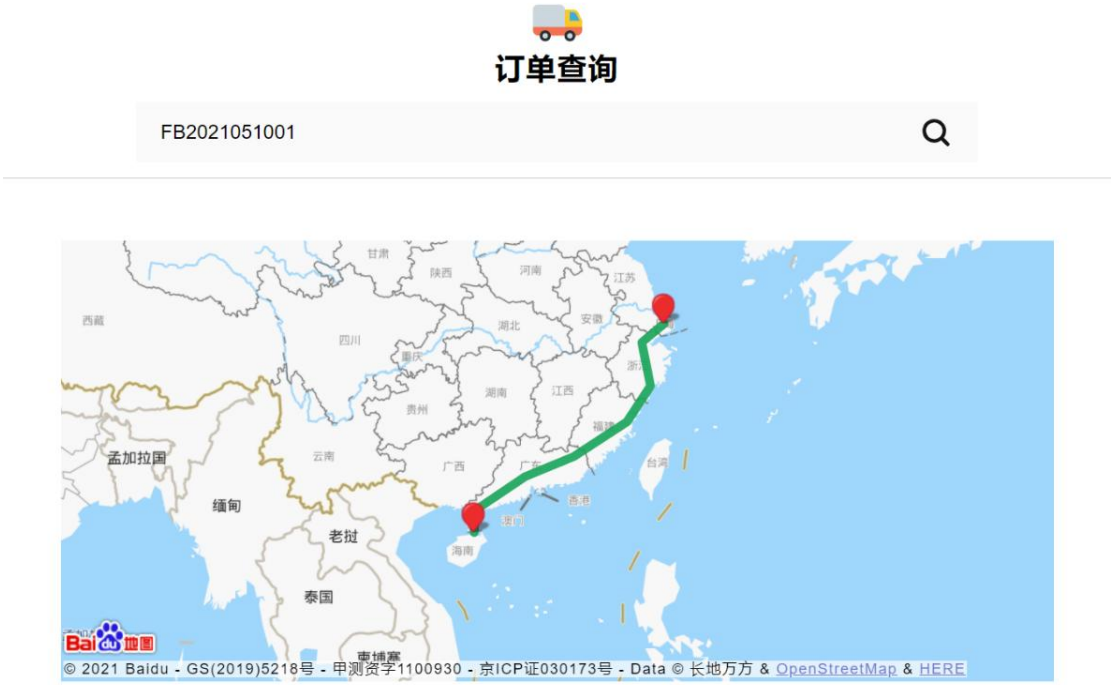


图 2.3 位置信息可视化界面

2.3.2 SDP 网络隐身模块

（1）网络架构设计

软件定义边界（Software-Defined-Perimeter，SDP）作为零信任安全的一种实践落地技术架构，打破了旧式边界防护思维，从传统的以网络为中心转变为以身份为中心进行最小权限访问控制。

基于 SDP，我们设计了项目的网络架构，如图 2.4 所示，其主要包含五个部分，分别为客户端、隐身安全网关、管控平台、连接器和应用服务器。接下来将详细介绍

其组成与作用。

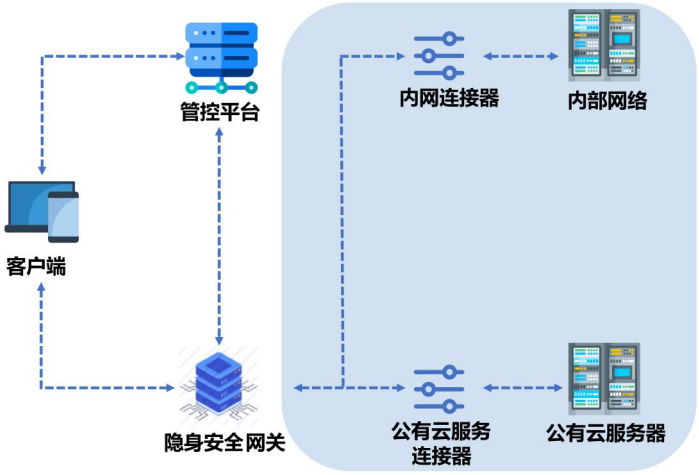


图 2.4 网络总体架构

1. 客户端

客户端以 Web 形式在终端用户、快递员、中转站理货员、管理员的设备上运行，用于与管控平台通信以请求物流服务，同时向管控平台发送设备或软件信息等数据。客户端通过 SPA 首包认证协议携带多因子用户认证信息，管控平台对其进行验证，并返回隐身网关 IP 列表以及权限列表。

2. 管控平台

管控平台用于对接入的用户客户端进行身份验证，管理隐身网关。管控平台自身具备安全策略管理和日志审计功能，能够动态管控用户的认证和授权，并对其进行信任评级。

3. 隐身安全网关

隐身安全网关可对访问请求进行验证和过滤，在默认情况下，网关拒绝所有的连接请求，只有管控平台下发认证策略后，才动态接受指定客户端的连接，并通过加密传输的方式代理客户端与业务服务器数据通信，同时根据管控平台下发的访问控制策略，管理通信过程。

4. 内网连接器

内网连接器部署于应用服务器和隐身网关之间，提供经过身份验证的安全接口，运行时不需要任何入站开放端口，且企业内部应用程序仅通过连接器与网关连接，无需对公网开放，以保证业务服务器仅对授权的设备可见。

5. 业务服务器

对外用户实现寄件、取件等完整物流业务，对内部员工实现货物交接、人员管理等内部业务。

（2）网络隐身技术实现

我们的项目采用 SDP 架构，其中应用服务器被隐藏在 SDP 网关之后，实现“先认证后连接”，从而只有被授权的用户才能可靠地访问，而未授权用户则对服务不可见，进而实现了服务隐身。网络隐身原理如图 2.5 所示。

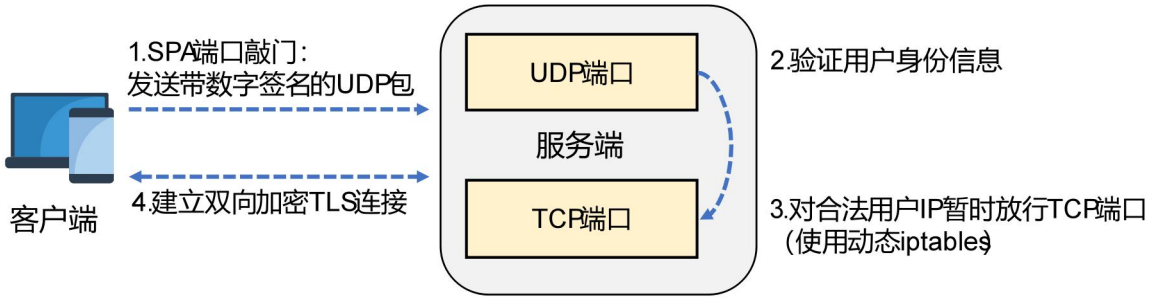


图 2.5 网络隐身原理

（3）认证流程

单包授权网络协议（SPA）作为网络通信的一种授权认证手段，可以有效地防范未信任数据包的风险。我们的项目选择使用 SPA 来实现网络隐身，其数据包包括请求方的 IP 地址、端口号等在内的连接请求的信息，在单一的网络信息中被加密和认证，通过配置默认丢弃（Default-Drop）的防火墙策略使保护的服务对外不可见，即防火墙系统应该丢弃所有 TCP 和 UDP 数据包，不回复连接尝试，从而有效阻止恶意用户任何关于端口信息的信息收集。认证处理流程如图 2.6 所示。

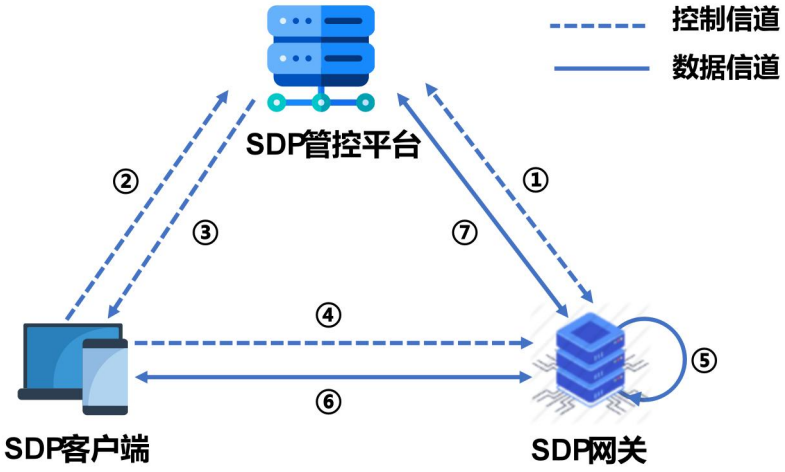


图 2.6 详细认证流程

① SDP 管控平台初始化，开启网络服务并建立与 SDP 网关的双向 TLS 通道。

② 用户访问 SDP 客户端，使用单数据包授权（SPA）向 SDP 管控平台发出访问请求，其中包含认证信息。

③ SDP 管控平台验证用户信息及系统环境信息，检查上下文，并将实时授权通过加密的 Token 传递给 SDP 客户端。

④ SDP 客户端使用 SPA 技术并附带实时授权信息，向 SDP 网关发出请求。

⑤ SDP 网关根据请求信息和预设的安全策略进行验证与匹配，选择允许或拒绝用户的访问请求。

⑥ SDP 网关为被允许的访问请求建立双向加密连接，客户端通过双向加密隧道和 SDP 连接器访问应用服务器，进行寄件、取件、货物管理等业务。

⑦ SDP 管控平台持续动态地监控用户信息和访问行为，进行信任等级评估并实时调整授权状态。

（4）网络控制组件

我们选用开源项目 Fwknop（https://github.com/mrash/fwknop）作为 SPA 实现单包授权技术方案。具体网络控制组件如下图 2.7 所示，接下来将详细阐述各层设计与实现。

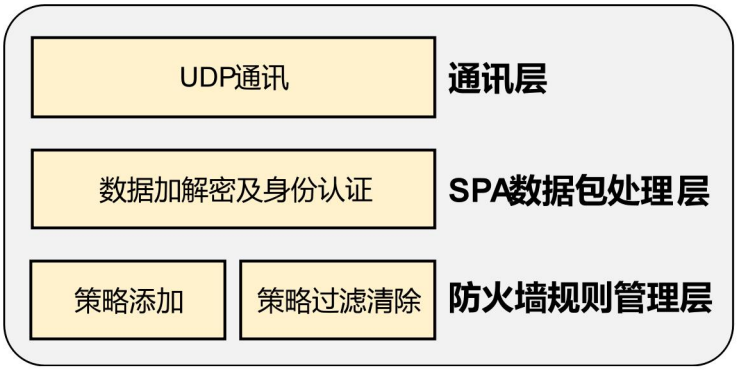


图 2.7 网络组件架构图

1. 网络通信层

由于负责网络通信的服务应用易被如 Nmap 等网络扫描器侦测，也易被 DDoS 攻击，同时一旦服务端口被识别，也会增加网络攻击的概率。因此需要通过抓包方式直接拿到请求授权包。在我们的项目中，通过设置防火墙 ACL 访问控制列表，将部署 Fwknop 服务的 SDP 管控平台的 iptables 默认拒绝一切数据包的连接，丢弃一切数据包。然后通过 libpcap 从物理网卡上被动地嗅探 Fwknop 客户端发出的单个 UDP 数据

包，以实现网络通讯。

2. 数据加解密及签名验证

SPA 请求授权数据包必须保证完整性和安全性，Fwknop 将单个携带认证信息的 UDP 数据包使用 AES 算法对称加密，同时利用嵌入 SHA-256 的 HMAC 算法保障数据传输的完整性以及防重放攻击。在 UDP 数据包被管控平台抓取并解密后，对数据包携带的认证信息进行多因子验证，包括用户身份信息、设备信息、网络环境等（详见身份鉴别与管理功能模块），在验证客户端身份以后，管控平台允许客户端通过端口 443 上的双向 TLS 进行连接通讯。

3. 防火墙策略

通过防火墙安全策略可以控制内网访问外网的权限、控制内网不同安全级别的子网间的访问权限。在我们的项目中，由于客户端封装了 Fwknop 服务，在 Fwknop 服务端嗅探到合法的客户端发送过来的数据包后，会暂时授予被动认证的 Fwknop 客户端的访问权限，具体实现为向主机上自定义的 iptables 链中添加和删除（在可配置的超时之后，同时 iptables 会利用连接追踪机制保持已有的连接不会被中断）相应服务的 ACCEPT 规则，以便 Fwknop 不会干扰可能已经加载到系统上的任何现有 iptables 策略，最终实现授信终端的接入。

2.3.3 多因子认证模块

多因子认证是零信任架构的第一道关卡，此认证采集多源信息，并从用户身份、系统环境、用户动态行为等多维度进行，不管是用户登录还是各类业务请求，都需经过多因子认证平台的验证，才能继续进行信任评估和授权，进而完成请求。

在认证之前，首先需要在 SDP 客户端进行多源信息数据的采集，包括对用户动态行为和物理系统信息采集，之后送至 SDP 管控平台进行多因子认证。多源信息采集内容如图 2.8 所示。

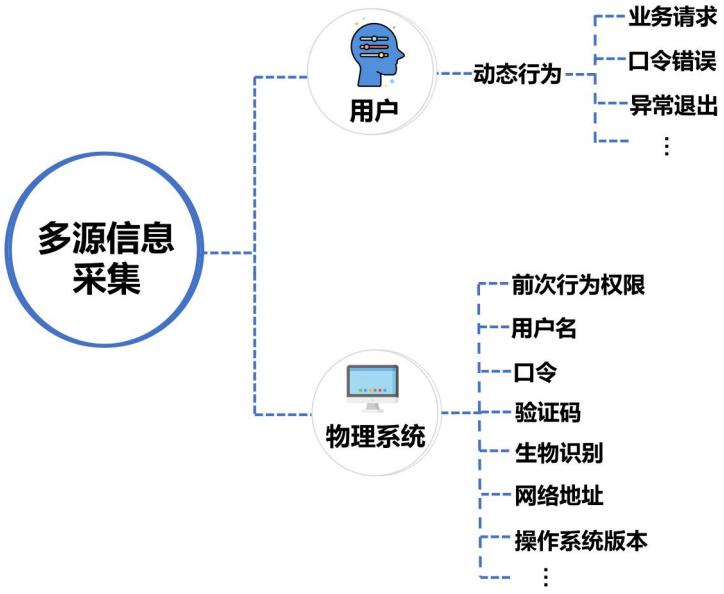


图 2.8 多源信息数据采集

采集完多源信息之后，用户需进行多因子的安全检验，本系统根据不同角色的用户采集信息进行认证，不同角色需要对自己身份进行验证。

物流服务的客户：是较为灵活的一类用户，他们只需提供自己的用户名和口令，用户名和口令的摘要将与系统数据库中的数据进行比对，两者匹配成功则通过认证，若出现用户名不存在等情况将会通过弹窗进行提示，认证通过后才可继续申请权限并进行业务请求。

物流企业的员工：除需要进行用户名和口令的认证外，还需验证码验证，以防止员工账户口令被恶意破解，造成损失。

物流公司的管理员：需提供更多的验证信息，除常规的用户名和口令外，还需验证码、生物识别等。由于管理员涉及系统最机密和关键的部分，所以本方案要求管理员的身份验证必须在企业的安全环境中，不仅是指有着生物识别设备和内部登录设备的物理环境，还是指企业的内网环境，以提供最安全的保障。因此管理员进行业务请求必须首先满足生物识别设备的认证以及固定的企业内部登录设备，继而再进行用户名、口令和验证码的认证。同时对于所有用户角色，系统都将会自动保存用户的前一次行为权限，作为后续认证的基础。

同时，SDP 客户端将用户设备相关信息发送至 SDP 管控平台进行系统环境认证。由于 Web 端限制，本系统将采集设备的操作系统版本和网络地址等信息。操作系统版本可以作为安全环境评估的参考，而网络地址信息则可检测用户登录位置是否突然

发生改变，给出相应的提醒。系统环境的认证可以确保设备自身状态足够安全，所以在对账户的登录时间、登录 IP 地址等动态行为进行严格控制的同时，确保用户在安全的设备上使用正确账号登录，以防止非法人员非法接入业务系统。

多因子认证需要对用户动态行为进行认证。用户动态行为极大影响系统的安全性，若用户相关动态行为异常，将严重影响信任评估的分值（在 2.3.4.1 详细描述）。此处我们采集的用户动态行为包括：反复登录但口令错误、异常退出、业务请求超出所属角色权限等不合理行为。系统将其统一发送至 SDP 管控平台，进行评估后以历史行为进行保留，作为后一次动态行为认证的重要依据。

2.3.4 动态授权模块

为了持续监测物流场景中的参与用户（客户、员工、管理员）的实时状态，并进行动态信任评估和授权状态调整，物流过程中的所有参与用户在进行业务请求时，首先需进行多因子认证。通过认证之后其访问鉴权依赖动态信任评估结果，且信任评估是持续的，伴随整个访问过程。一旦访问过程中物流参与用户发生行为异常或环境异常，则会自动调整访问权限，保证业务访问的最小权限。本模块由多因子认证平台、动态信任评估平台和访问控制平台组成，如图 2.9 所示。

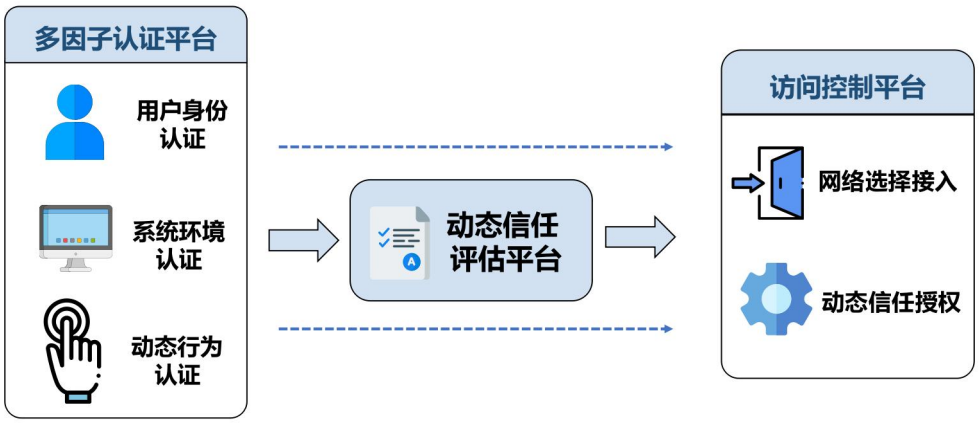


图 2.9 整体架构

2.3.4.1 动态信任评估平台

本平台根据多因子认证平台的认证结果，对物流参与人员分别进行动态信任评估。平台具有解析、评估和决策能力，如图 2.10 所示。

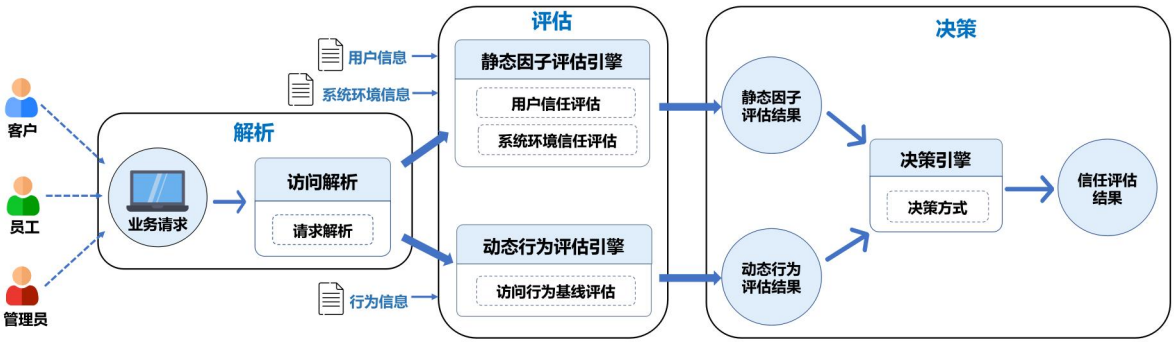


图 2.10 动态信任评估平台整体架构

（1）解析模块

物流场景中的各个用户在客户端发出业务请求，并发送至 SDP 管控平台进行访问解析。访问解析亦从业务请求中提取涉及用户实体、设备实体、用户动态操作等信息，并对访问请求转换为信任引擎可以处理的标准化格式。最后将这些用户、资源等信息传递给静态访问评估引擎和动态行为评估引擎进行下一步信任评估。

（2）评估模块

根据收集到的相关信息与访问请求，信任评估平台动态评估物流场景中的各个用户。评估能力中包括静态因子评估引擎和动态行为评估引擎，每个引擎单独根据确定的评估规则对其内部因子进行评级。

1. 静态因子评估引擎

此引擎对用户和设备等实体根据确定的评估规则对静态因子进行信任评估，静态因子包括用户实体认证、设备实体认证、OTP 认证、生物识别认证、前次行为权限认证等。由于不同物流参与用户拥有不同的静态因子，同时因子的侧重量也有差别，在统计和分析大量物流相关数据和资料之后，此引擎详细制定了适用于物流场景中不同用户的静态因子评估规则。表 2.2 详细说明了本引擎对不同用户的评估规则，每个类型的用户单独进行其拥有因子的评估。

表 2.2 静态因子评估规则

评估项 / 用户	身份认证	设备认证	OTP 认证	前次行为权限认证	生物识别认证
客户	40%	30%	/	30%	/
员工	35%	30%	15%	20%	/

管理员	25%	25%	10%	20%	20%

2. 动态行为评估引擎

此引擎接收物流参与用户的资源访问请求，并根据请求用户的行为特征（动态因子），结合上下文的行为信息，检测当前用户行为的异常风险。此处动态因子的判定指相关用户参与物流运输中的所有行为活动，主要包括；

客户：恶意投诉、反复切换账号等。

员工：私自开箱客户包裹、长时间未进行工作操作等。

管理员：向系统注入威胁病毒、私自泄露和删除用户信息等。

（3）决策模块

在静态因子评估引擎和动态行为评估引擎对相应因子进行评估之后，每个引擎单独传递信任评估信息至决策模块。首先进行单个信任引擎量化评分，其初始评判总分均为 100 分，一旦不能通过相关认证或者检测到异常风险，则根据评估规则进行动态扣分。每个信任引擎的评估结果上传至决策引擎之后，决策引擎根据决策方法（使单独两个信任评估结果取平均值）进行综合量化评分得出最后的信任评估结果。且决策模块针对不同的物流参与用户有着不同的信用加减分决策规则，下面详细描述不同用户对应的决策规则。

1. 客户账号

① 进行扣分之后，物流信任评估平台设置 3 天考察期，从扣分当日当时开始计算。

② 若 3 天之内无任何扣分行为，则恢复之前所扣除的信用分。

③ 若 3 天之内仍有扣分行为，则进行累计扣分，并从前一扣分日重新计算恢复时间。

④ 若在初始扣分日之后 1 个月内，扣分行为达到 15 次，则将用户账号列为失信名单，不再对此客户提供物流服务。

2. 员工账号

① 进行扣分之后，物流信任评估平台设置 7 天考察期，从扣分当日当时开始计算。

② 若在 7 天内无任何扣分行为，则恢复之前所扣除的信用分。

③ 若在 7 天内仍有扣分行为，则进行累计扣分，并从前一扣分日重新计算恢复时间。

④ 若在初始扣分日之后 7 天内，扣分行为达到 4 次，则进行账号冻结，并进行物流公司相关内部处理惩罚。

3. 管理员账号

① 进行扣分之后，物流信任评估平台设置 30 天考察期，从扣分当日当时开始计算。

② 若在 30 天内无任何扣分行为，则恢复之前所扣除信用分。

③ 若在 30 天内仍有扣分行为，则进行累计扣分，并从前一扣分日重新计算恢复时间。

④ 若在初始扣分日后 30 天内，扣分行为达到 3 次，则立即进行账号冻结。

⑤ 若管理员造成公司损失、用户隐私泄露等重大事故，信誉分直接归零，并立刻冻结账号，拒绝该账号今后任何访问请求。

每个物流参与用户访问级别可能随时改变，通过多方因子统计和评估，能够动态推断出分配给用户不同信任等级。表 2.3 体现了决策分数对应的最后评估等级结果。

表 2.3 决策分数评估等级

决策分数	等级
100 分	A 级
86-99 分	B 级
60-85 分	C 级
60 分以下	D 级

2.3.4.2 访问控制平台

在进行多因子认证与信任评估之后，此平台对物流参与的用户进行动态信任授权，保证物流场景下的动态访问控制体系。本平台包含网络选择接入、和动态访问授权两大模块。

网络选择接入：当物流参与用户参与对相关资源发起访问时，通过多因子认证平台对请求用户进行预认证。认证通过之后，根据其本身的相关角色进入不同的动态信任授权模块。

动态访问授权：根据最小权限原则，给予不同物流参与用户的最高权限不同，在 A 级评级下，给与当前用户可执行的最大权限，在等级波动之后动态给予相应权限。

基于多因子认证和信任评估等级，平台根据用户在自己的可视界面中能操作的选项，进行动态授权。表 2.4 展现了不同用户在不同等级的权限设置管理策略。

表 2.4 人员动态权限管理策略

用户	等级	访问权限
客户	A	监控访问
	B	限制访问&监控访问
	C	
	D	拒绝访问
员工	A	监控访问
	B	限制访问&监控访问
	C	
	D	拒绝访问
管理员	A	完全访问&监控访问
	B	限制访问&监控访问
	C	拒绝访问
	D	

2.3.5 数据管理模块

2.3.5.1 链下数据管理

基于 FISCO BCOS 的物流交易数据管理方案分为三个阶段：发送阶段、转送阶段和接收阶段，三个阶段根据功能互相衔接、依次进行。每个阶段包含多次物流交易过程，每次交易中的递送人员为执行者，接受包裹的人员为交易对象，由此产生交易块。发送阶段中，发送者在寄件站点产生第一个交易块。进入转送阶段，途径的$n-2$个站点（不计寄件站点与代收站点），每个站点的理货员和不同收发快递员产生两个交易块。同时寄件站点送出包裹产生的交易块与代收站点收入包裹产生的交易块一同算入此阶段，因此本阶段共有$2n-2$个交易块。接收阶段中，代收站点的理货员会与接收者产生一个表示已经递交完成交易块。最后接收者进行包裹确认后与代收站点的理货员产生最后一个交易块，整个包裹交易过程共产生$2n+1$个物流交易块。图 2.11 展示了链下数据管理流程。

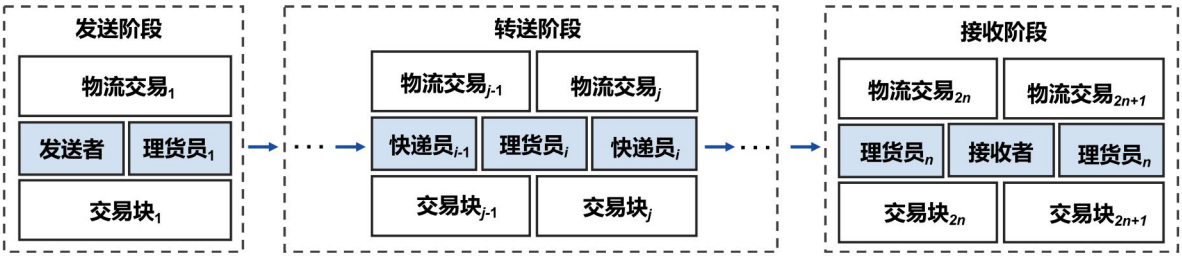


图 2.11 链下数据管理流程

（1）发送阶段

在发送阶段，第一个物流交易记录块的产生由发送者将寄件的包裹递送给寄件站点的理货员，理货员根据包裹物流信息的必需明文信息，将包裹分配给快递员开始传送。产生的交易块如图 2.12 所示。

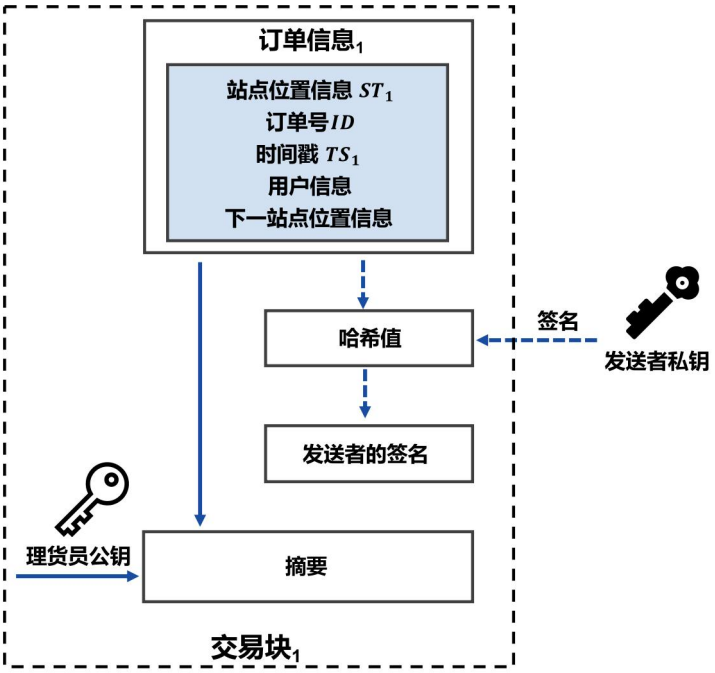


图 2.12 发送阶段的物流交易块

本次交易的寄件站点作为初始站点，发送者通过用户界面填写个人及物流信息，系统经与服务器交互后产生第一个订单信息，其中包含了该站点位置信息ST_1、订单号ID、产生的时间戳TS_1、用户信息及下一站点位置信息。发送者通过确认提交的选项，利用本地存储的私钥使用 SM2 算法对第一个订单信息的哈希值（由 SM3 算法计算得到）进行数字签名，该订单信息、哈希值以及签名再通过双向加密的隧道传输至服务器。同时服务器进行摘要对比以及签名验证以保证订单的完整性和可信性，若验证失败，该次请求将失效并要求用户重新提交。最后对该订单信息和第一个理货员的公钥通过 SM3 进行哈希计算，得到摘要并上传至区块链，最终形成第一个交易块。

（2）转送阶段

进入包裹的转送阶段，第$i(1<i\leqslant n)$个站点的理货员收到上一个站点的快递员送来的包裹后，根据最小泄露原则解密得到必需的物流信息，即下一站点位置信息，再将其分配给本站的快递员继续传送，如图 2.13 所示。

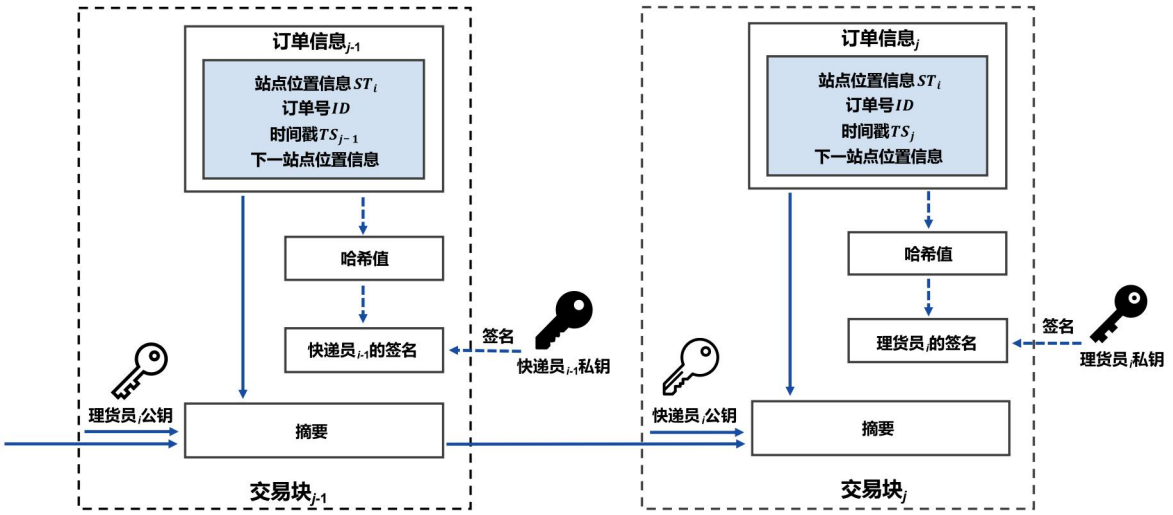


图 2.13 转送阶段第 i(1<i≤n)个物流站点上的物流交易块

由于第一个交易块里已包含用户信息，所以第$i-1$个快递员只需将目前到达的物流站点位置信息ST_i、订单号ID、时间戳TS_{j-1}及下一站点位置信息加至第$j-1$个订单信息中，再通过自己的私钥使用 SM2 算法对第$j-1$个订单信息的哈希值进行数字签名。最后对本次订单信息、上一个交易块中的摘要和第i个理货员的公钥使用 SM3 算法进行哈希计算得到摘要，产生第$j-1$个交易块。

完成与第$i-1$个快递员的物流交易后，第i个理货员根据下一站物流地址，指派快递员继续转送包裹，由第i个快递员负责运输此包裹到第$i+1$个站点。第i个理货员将本站点位置ST_i、ID、TS_j及下一站点位置加入到第j个订单信息中。第i个理货员通过其私钥使用 SM2 算法对该订单信息的哈希值进行数字签名。最终对本次订单信息、上一个交易块中的摘要和第i个快递员的公钥使用 SM3 算法进行哈希计算得到摘要，产生第j个交易块。

在转送阶段中，重复上述交易过程，直到包裹到达目的地代收站点即$i=n$，包裹的转送阶段结束，进入接收阶段。

（3）接收阶段

包裹到达代收站点时，该站点的理货员向快递公司服务器发送包裹已到达信息。

服务器收到后对向代收点和收件人均发送取件码。收件人收到取件信息后，到代收点报取件码和手机号码后四位数字，快递员进行核对并匹配，取件成功。收件人签收完毕，通过物流系统的消息应答，进行确认收货。详细过程如图 2.14 所示。

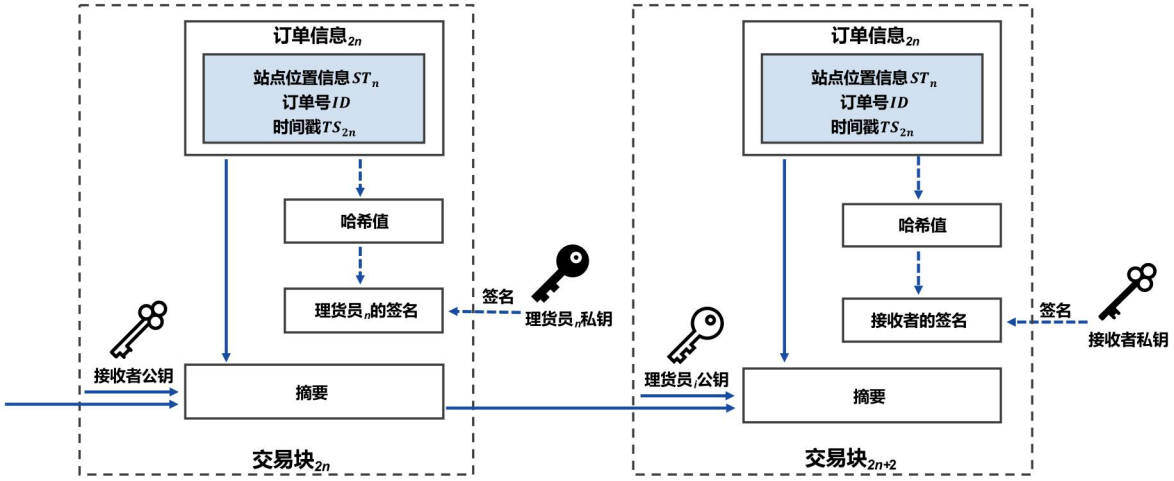


图 2.14 接收阶段的物流交易块

代收点的理货员找到包裹并验证接收者的身份，接收者也验证包裹真实性后，收下包裹。第n个理货员将本站点位置ST_n、ID、时间戳TS_{2n}一同加入到第$2n$个订单信息中。第n个理货员通过自己的私钥使用 SM2 算法对该订单信息的哈希值进行数字签名。最后对本次的订单信息、上一个交易块中的摘要和接收者的公钥使用 SM3 算法进行哈希计算，得到摘要，最终产生第$2n$个交易块。

接收者拿到包裹后，再向系统发送确认已收到包裹的消息，并产生第$2n+1$个交易块，此时该包裹的物流交易过程结束。接收者将代收点位置信息ST_n、ID及时间戳TS_{2n+1}一同加入到第$2n+1$个订单信息中。接收者通过自己的私钥使用 SM2 算法对该订单信息的哈希值进行数字签名。最后对本次的订单信息、上一个交易块中的摘要和代收点理货员的公钥使用 SM3 算法进行哈希计算，得到摘要，最终产生第$2n+1$个交易块。

2.3.5.2 链上数据管理

链下数据管理中三个阶段均由交易的执行者对订单信息的哈希值进行数字签名，并与摘要、订单号ID一起组成区块上传至 FISCO BCOS 中，以完成交易记录的上链。因为一次订单的完成是多个环节的，在未完成之时进行评估并不合理。所以对于某一包裹的交易全过程，我们将会在流程结束后将物流过程中所有参与用户的最终信任评

估分数上传至区块链，以便企业管理者进行查看和管理。完成物流交易信息和评估分数上链的整体流程如图 2.15 所示。

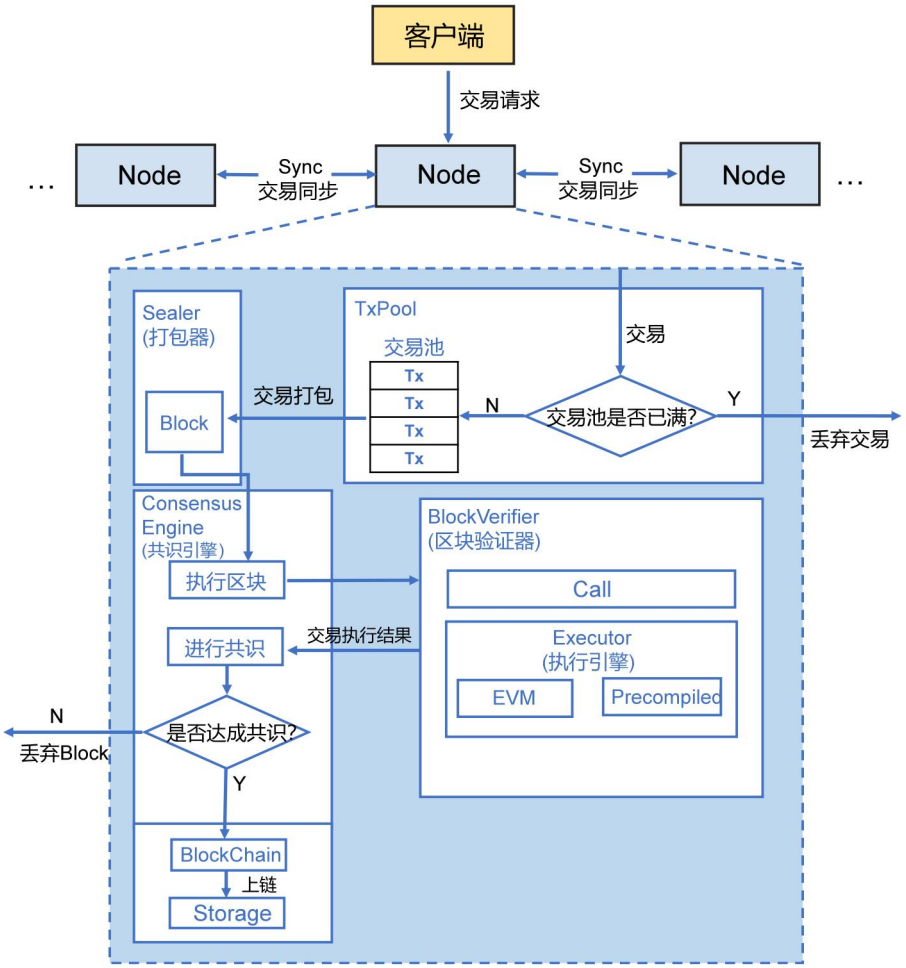


图 2.15 数据上链流程

详细描述如下：

① 用户通过客户端发起交易。

② 节点收到交易后，若当前交易池未满则将交易附加至 TxPool 中并向自己所连的节点广播该交易；否则丢弃交易并输出告警。

③ Sealer 会不断从交易池中取出交易，并立即将收集到的交易打包为区块并发送至共识引擎。

④ 共识引擎调用 BlockVerifier 对区块进行验证并在网络中进行共识，BlockVerifier 调用 Executor 执行区块中的每笔交易。当区块验证无误且网络中节点达成一致后，共识引擎将区块发送至 BlockChain。

⑤ BlockChain 收到区块，对区块信息（如块高等）进行检查，并将区块数据与表数据写入底层存储中，完成区块上链。

2.3.5.3 数据跨域管理

（1）整体架构

为打通异构区块链之间的交互，根据实际物流跨域需求，我们提取出了主流区块链的三层体系结构抽象，如图 2.16 所示。

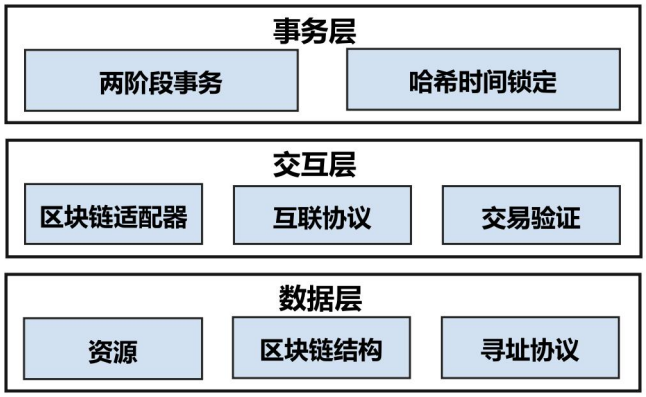


图 2.16 主流区块链三层体系结构抽象

为适应不同物流代理的大量相异的业务逻辑，本架构具有兼容目前主流区块链体系结构的能力，可实现灵活架构部署。同时支持用户跨域调用智能合约，并传递交互参数，实现智能合约跨域访问、智能设备跨域点对点互操作等功能。在本系统中，我们使用 WeCross 平台进行跨域操作，如图 2.17 所示。



图 2.17 跨域架构

下面描述本系统的跨域整体流程：

交易发起阶段：此阶段路由节点会监听并获取网络中的跨域请求，用户调用跨域合约发起子链 A 向子链 B 的跨域请求时，该请求会被路由节点获取，路由节点会对该请求进行验证，验证通过无误后将跨链请求信息提交到跨域消息队列中。如果检查中存在问题，则中止交易，返回错误信息。

交易路由阶段：子链 A 到子链 B 的跨域请求被送入消息队列后，中继合约监听到并查询验证对应请求信息，之后根据路由信息将请求转发至对应的子链 B。子链 B 的路由节点收到中继合约转发过来的跨域交易请求后，交易会被提交到子链的跨域合约中进行处理，其跨域合约对路由节点提交的交易进行校验，通过节点签名投票后提交候选区块，把相关信息同步给中继链，提交跨域反馈。

交易核验阶段：中继链收到子链 B 反馈的跨域信息后，首先对跨域交易进行简单支付验证。验证通过后，转发给跨域的发起者子链 A。跨域发起者子链 A 的路由节点监听到中继链发来的跨域确认信息后，向子链 A 提交跨域反馈，子链 A 会对该比跨域交易进行确认，把确认的跨域交易提交到跨域合约中；子链 A 的跨域合约对提交的确认交易信息进行校验，验证跨域交易确实来自于中继链，然后进行投票验证，保证交易的执行，同时返回相应的回执信息。

交易确认阶段：中继链收到反馈信息后，会进行简单支付验证，同时对相应的子链数据信息进行同步，等待子链确认跨域信息后候选区块变成正式区块。同时生成一个跨域存证，确保跨域交易真实有效。跨域存证生成后，标示此次跨域交易过程正常结束。

（2）详细步骤

我们创建物流代理 A 和物流代理 B 的物流信息链，两家代理只拥有其内部相关物流数据。此时代理 A 的用户需要访问代理 B 完成数据查询，并要求访问结果真实可信，详细步骤如图 2.18 所示。

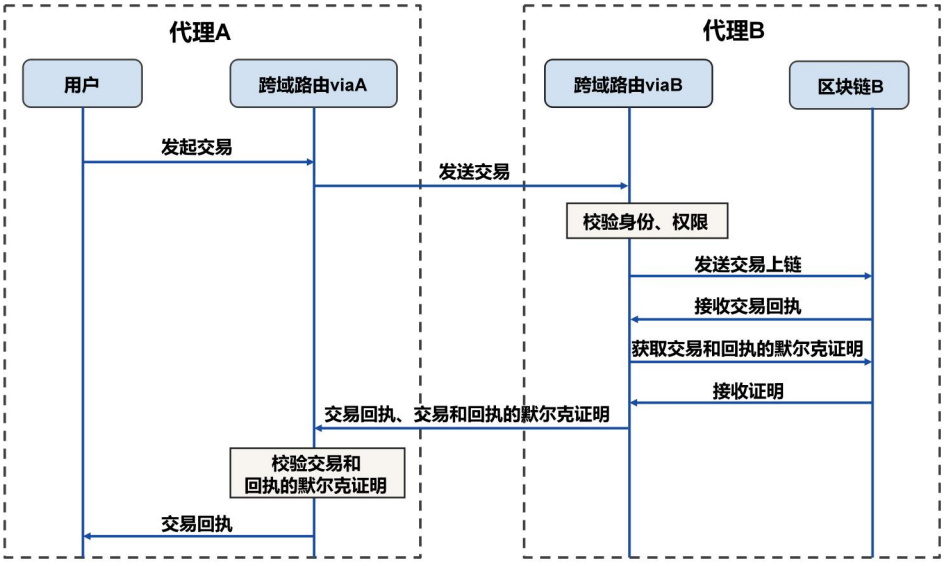


图 2.18 跨域详细步骤

详细如下：

① 用户用其账号提出交易请求并发起交易，之后将此交易发送至代理 A 的跨域路由 viaA 中。

② 跨域路由发送用户构造的交易到代理 B 的跨链路由 viaB 中，经由 viaB 验证此交易后将交易上链至代理 B 的区块链中，以保证交易公开安全可信。

③ 交易在区块链 B 上链后返还交易回执至 viaB，之后区块链 B 再从 viaB 中获取交易和回执的默尔克证明，其返回接收证明后再将交易回执、交易和回执的默尔克证明共同返回给 viaA，由 viaA 继续进行验证。

④ viaA 认证成功后，返回给用户交易回执。

第三章 作品测试与分析

3.1 测试环境

应用服务器配置如表 3.1 所示。

表 3.1 应用服务器配置信息

配置项	性能测试环境
CPU	Intel i5-9500 3.00GHz
MEM	8.00 GB
SSD	256G
操作系统及版本号	Ubuntu 20.04
数据库系统及版本号	Mysql 8.0.22

LoadRunner 客户端配置如表 3.2 所示。

表 3.2 LR 客户端配置信息表

配置项	性能测试环境
CPU	Intel i7-8750H 2.20GHz
MEM	8.00 GB
SSD	512G
操作系统及版本号	Windows 10 enterprise
数据库系统及版本号	8.0.22

3.2 功能测试

3.2.1 系统功能测试

（1）客户功能测试

1. 注册与登录

客户在使用本系统时，首先需要进行账户的注册。注册页面如图 3.1 所示，输入用户名（手机号）、密码和姓名，即可进行注册。

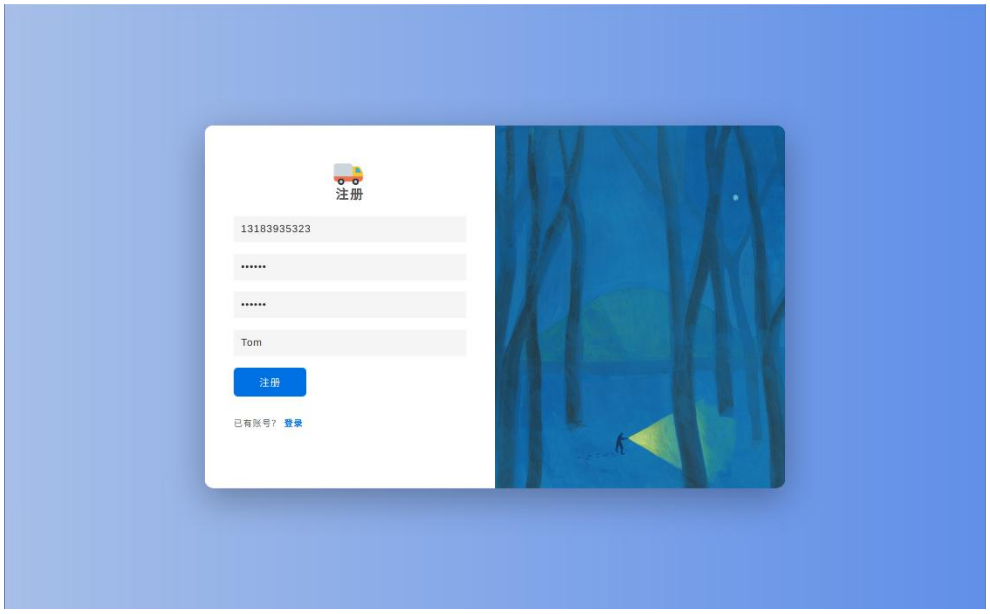


图 3.1 客户注册

客户端将为客户生成密钥对，如图 3.2 和图 3.3 所示，私钥保存在本地用于签名，公钥发送至服务端用于验签以及摘要计算。

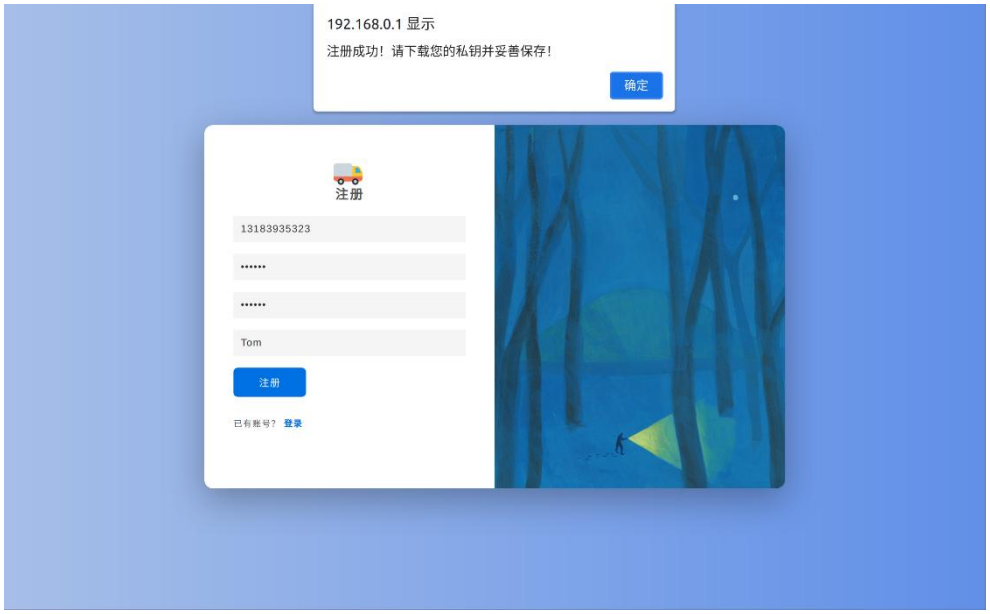


图 3.2 客户注册

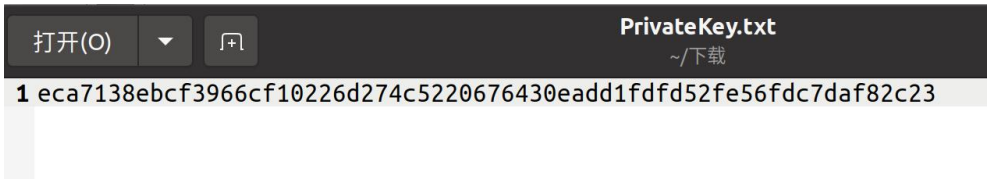


图 3.3 用户私钥的存储

同时注册页面将自动切换至登录页面，如图 3.4 所示，输入用户名和密码即可登

录。

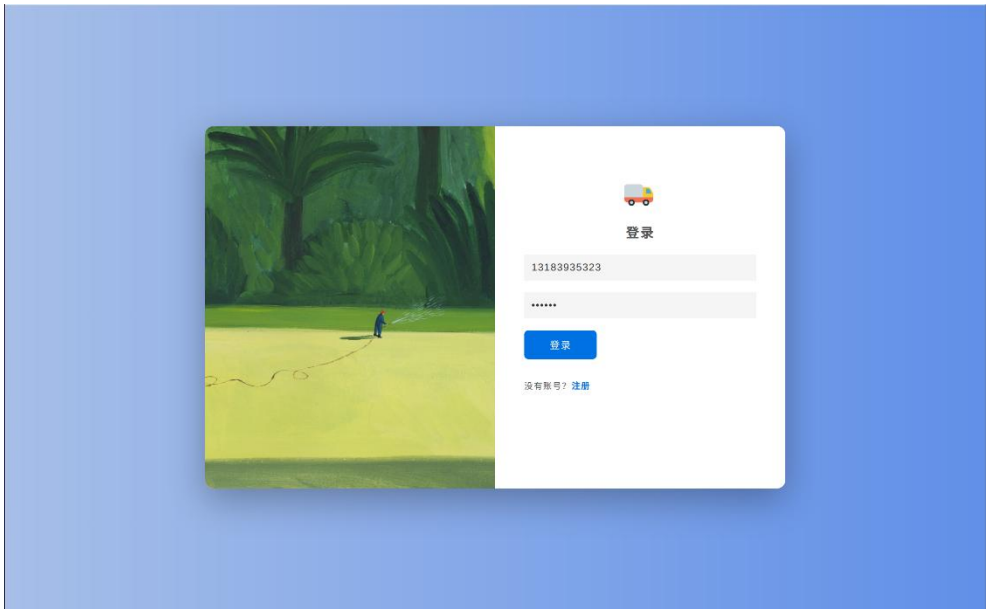


图 3.4 客户登录

2. 寄件

用户进入寄件页面后，如图 3.5 所示。填写寄件人、收件人相关信息及包裹信息，点击提交按钮，完成寄件。

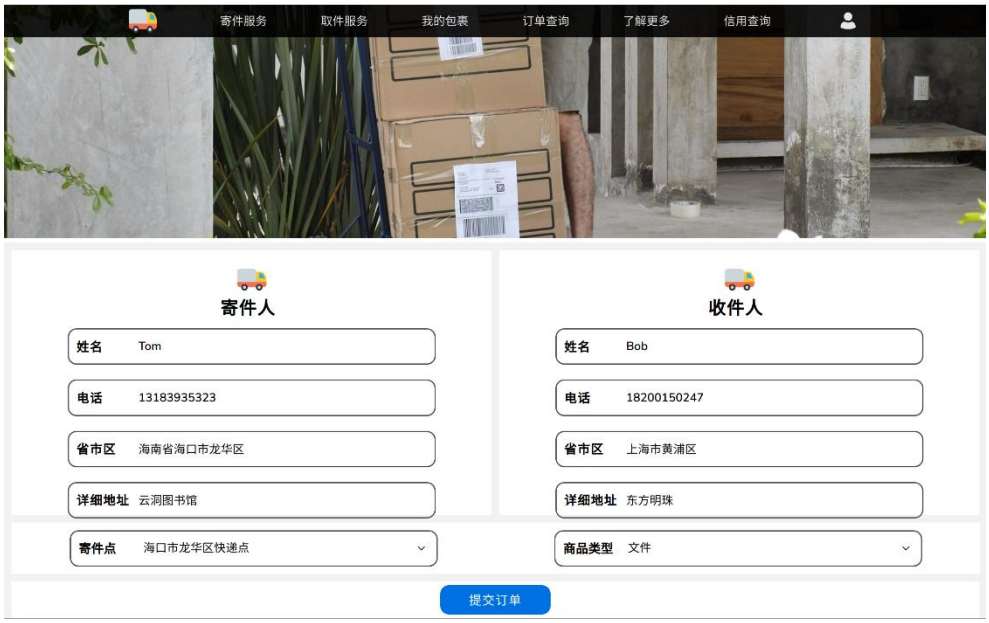


图 3.5 寄件

点击“提交订单”之后，用户输入私钥对该次交易进行数字签名操作。同时服务端将利用存储的用户公钥进行验签，如图 3.6 所示。身份验证成功后，即可完成寄件，同时上传至区块链保存，如图 3.7 所示。

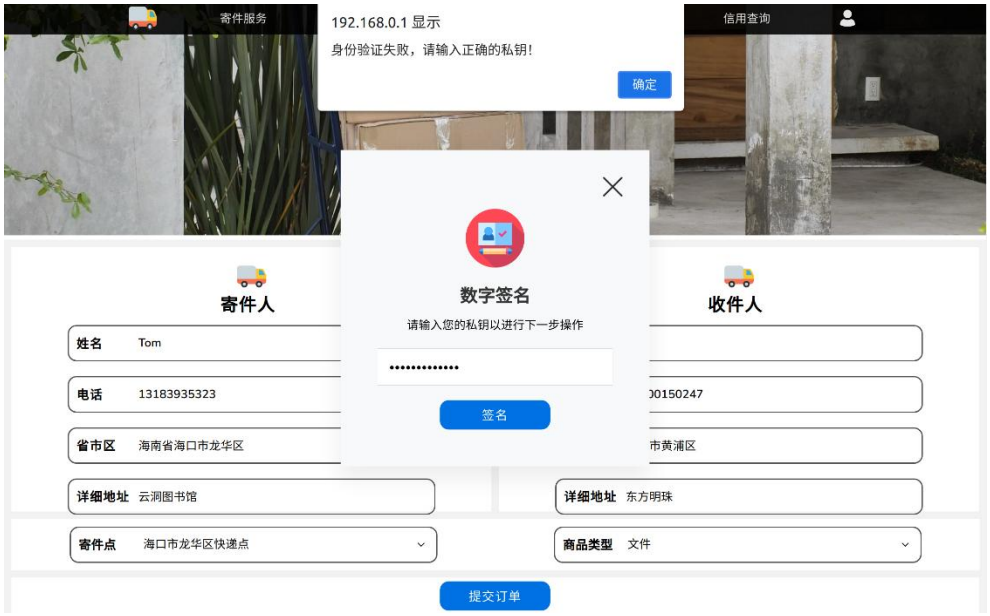


图 3.6 数字签名失败

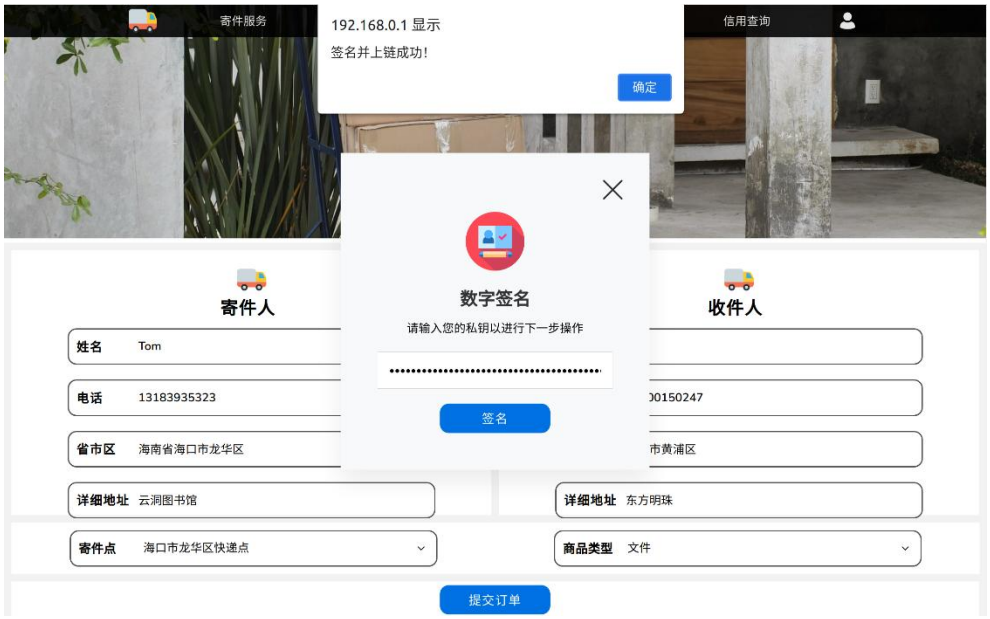


图 3.7 数字签名成功

3. 取件

如图 3.8 所示，用户可在取件页面查看待取件订单号、取件码以及代收站点。



图 3.8 待取件

4. 我的包裹

在我的包裹页面用户可查看已寄出和已收到的包裹，如图 3.9 所示。



图 3.9 我的包裹

5. 订单查询

在订单查询页面，用户可以通过订单号查询与自己相关联的包裹信息（本系统不允许用户查询与自己无关联的包裹），同时进行确认收货，并通过私钥对该次交易签名，如图 3.10 与图 3.11 所示。



图 3.10 订单查询

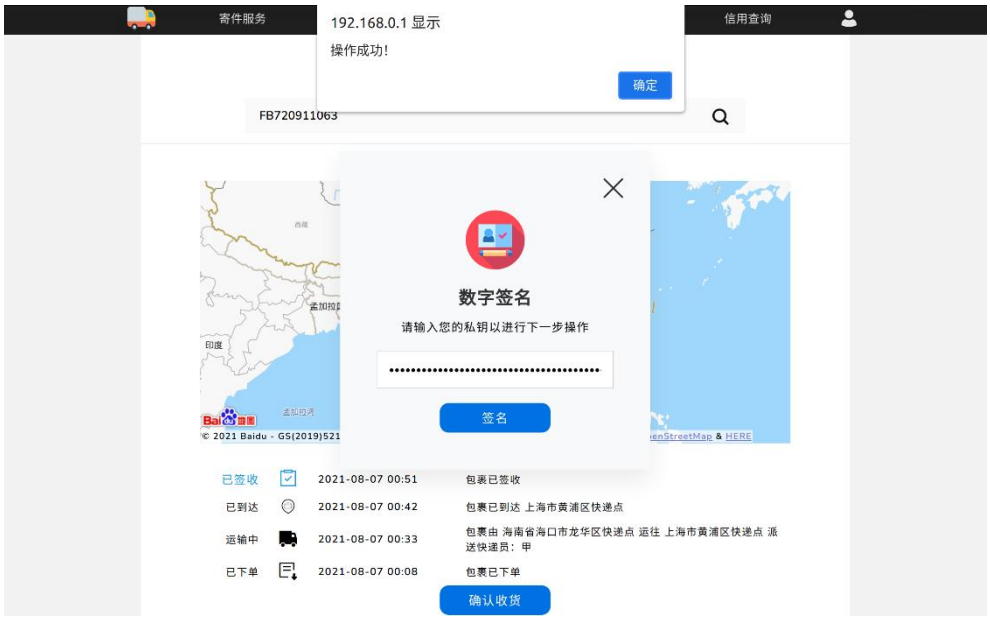


图 3.11 确认收货

6. 信用查询

如图 3.12 所示，客户可以在该界面查看目前的信用分数、等级和违规次数，同时了解评估规则。



图 3.12 客户信用查询

（2）理货员功能测试

1. 注册和登录

理货员在使用本系统时，首先需要进行账户的注册。注册页面如图 3.13 所示，相比于用户的注册，理货员还需输入所属快递站点。

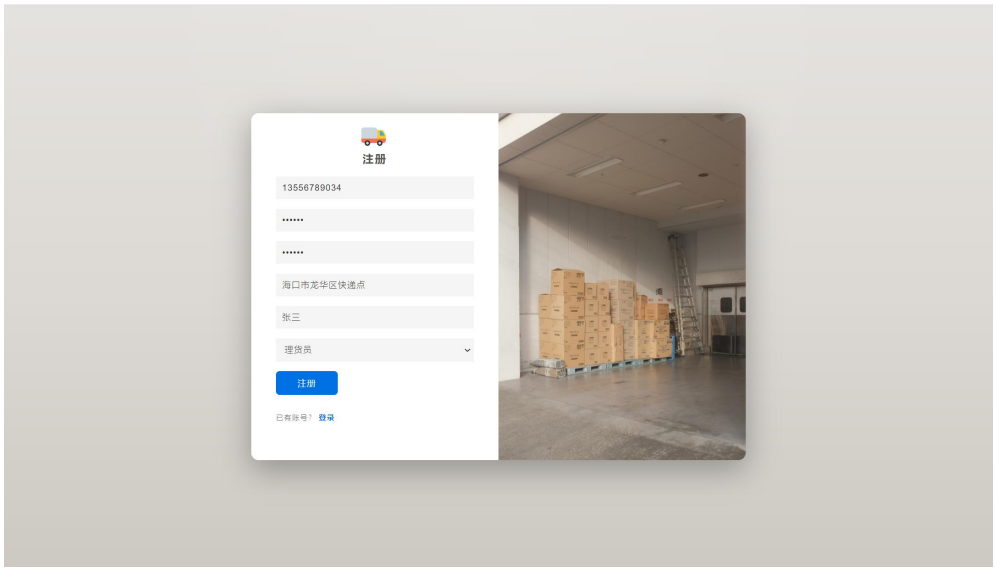


图 3.13 理货员注册

理货员注册成功后即可进行登录，除用户名和口令外，系统还将对理货员进行验证码认证，如图 3.14 所示。

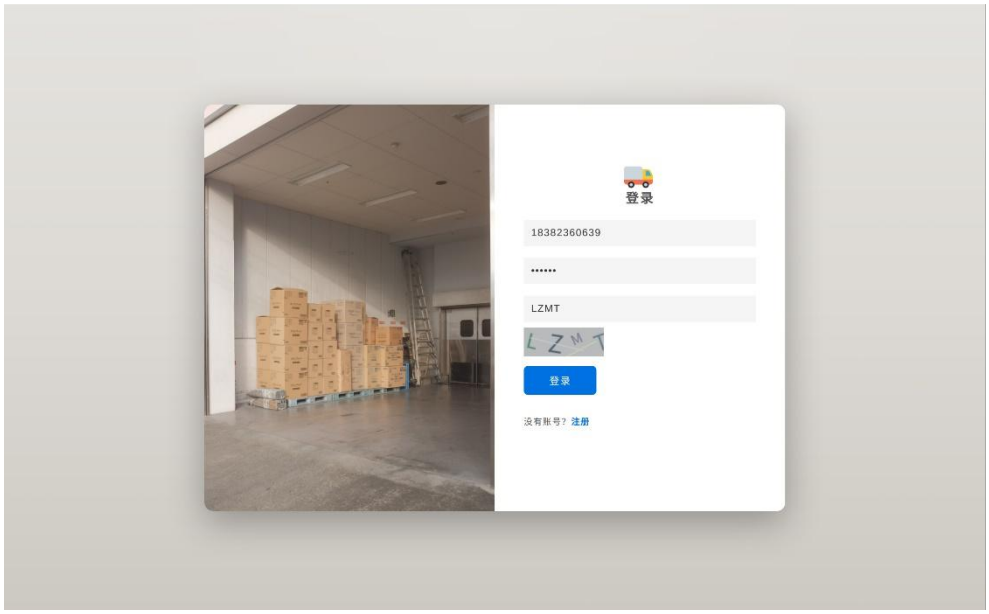


图 3.14 理货员登录

2. 员工管理

如图 3.15 所示，在员工管理页面，理货员可查看该站点已注册的所有快递员信息。



图 3.15 理货员员工管理

3. 订单处理

在订单处理页面，如图 3.16 所示，理货员可以为到达本站点的包裹安排相应的快递员。

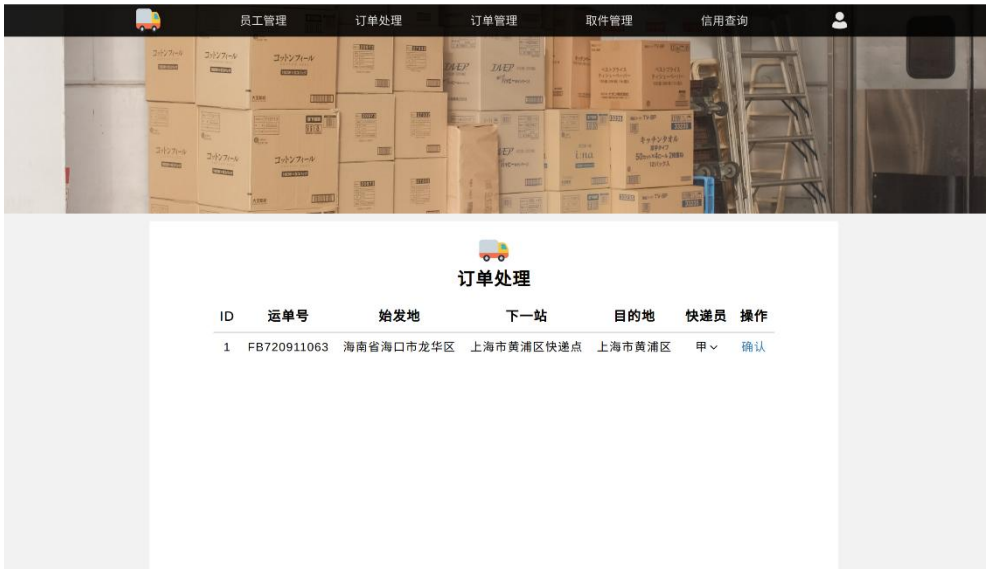


图 3.16 理货员订单处理

并输入自己的私钥对该次交易进行签名，如图 3.17 所示。

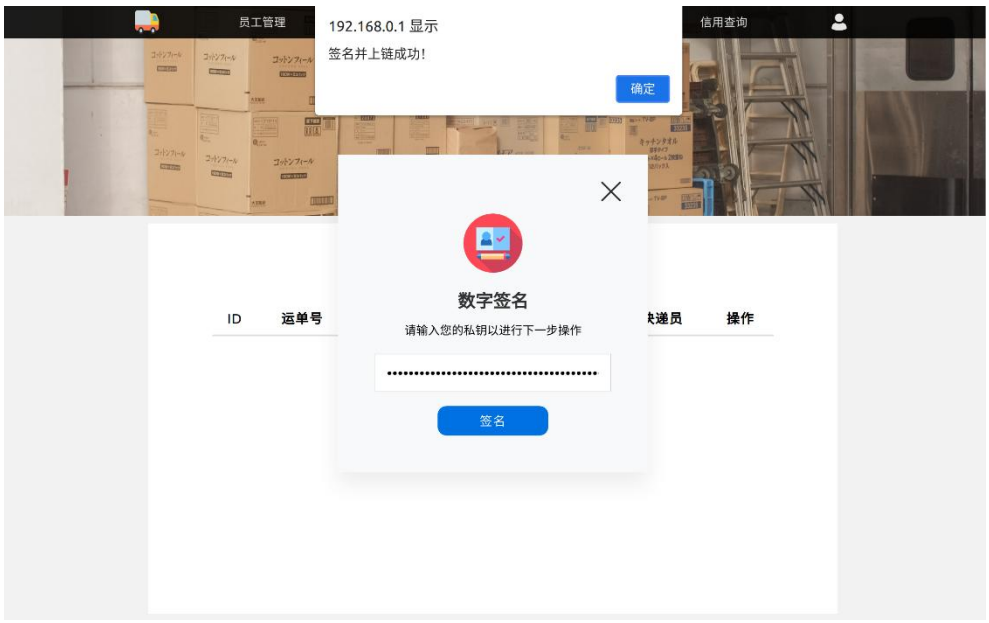


图 3.17 理货员数字签名

4. 订单管理

理货员可以在订单管理页面查看本站点已处理过的订单详情，如图 3.18 所示。

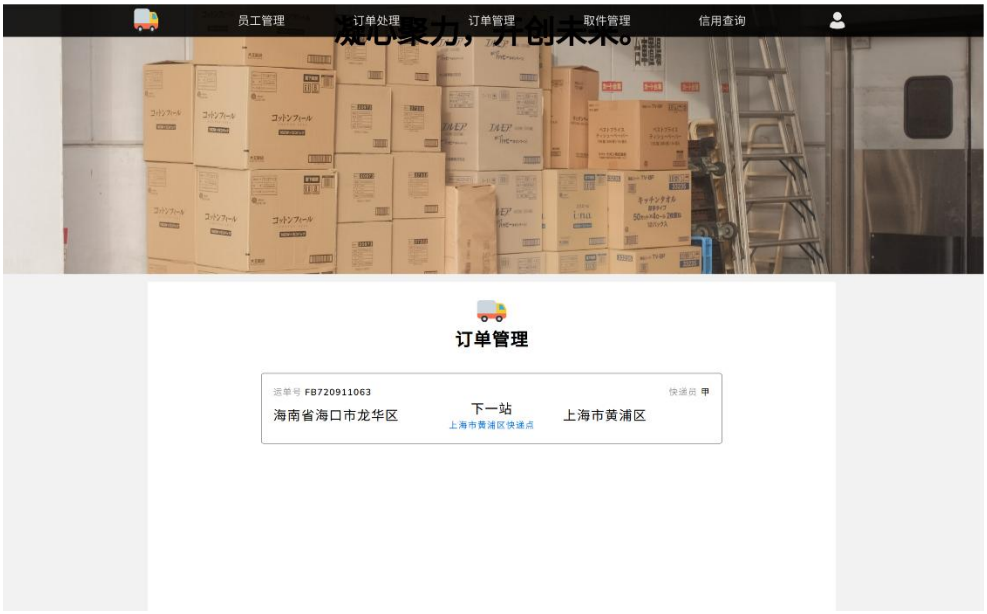


图 3.18 订单管理

5. 取件管理

如图 3.19 所示，理货员可以在取件管理页面查看待取件的运单号、取件码和手机尾号，匹配成功即可成功签收。



图 3.19 取件管理

6. 信用查询

如图 3.20 所示，理货员可以在该界面查看目前的信用分数、等级和违规次数，同时了解评估规则。



图 3.20 理货员信用查询

（3）快递员功能测试

1. 注册和登录

快递员注册和登录步骤与理货员一致，需输入用户名、密码、所属站点、姓名等信息，同时在登录时通过用户名、口令和验证码进行认证。界面分别和图 3.13 与图 3.14 类似，此处不再展示。

2. 订单派送

如图 3.21 所示，快递员在订单派送界面，可以查看待派送的订单，并在包裹到达下一站点后点击已到达按钮以完成订单。



图 3.21 订单派送

快递员进行操作同样需要进行数字签名，如图 3.22 所示。

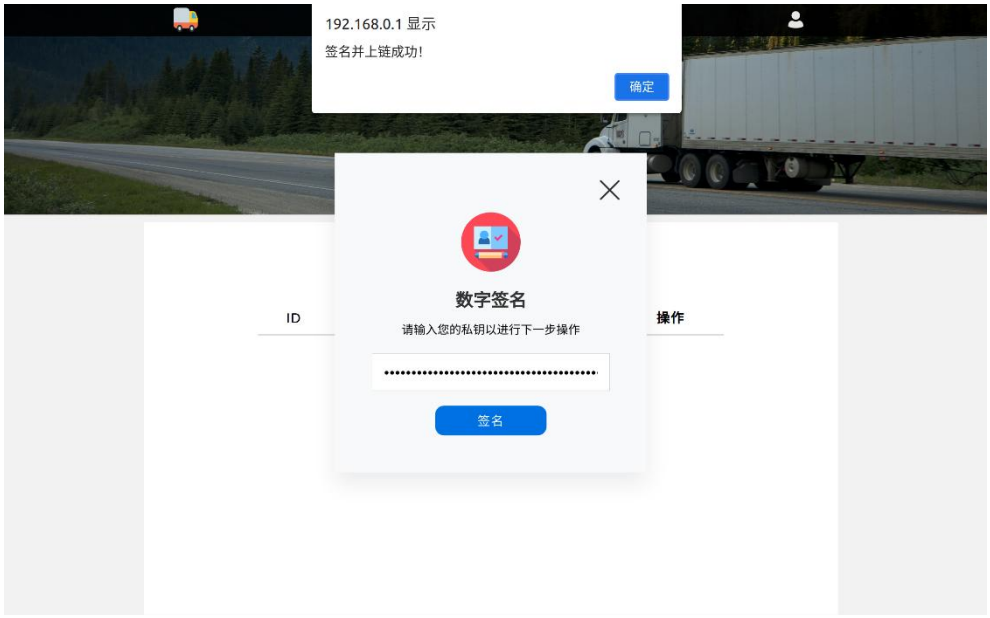


图 3.22 快递员数字签名

3. 信用查询

如图 3.23 所示，快递员可以在该界面查看目前的信用分数、等级和违规次数，同时了解评估规则。



图 3.23 快递员信用查询

（4）管理员功能测试

1. 登录

管理员进行登录时需要通过用户名、口令、验证码和生物识别。界面与图 3.14 相似，此处不再展示。

2. 员工管理

该页面如图 3.24 所示，管理员可以查看已注册的所有站点及站点理货员信息。

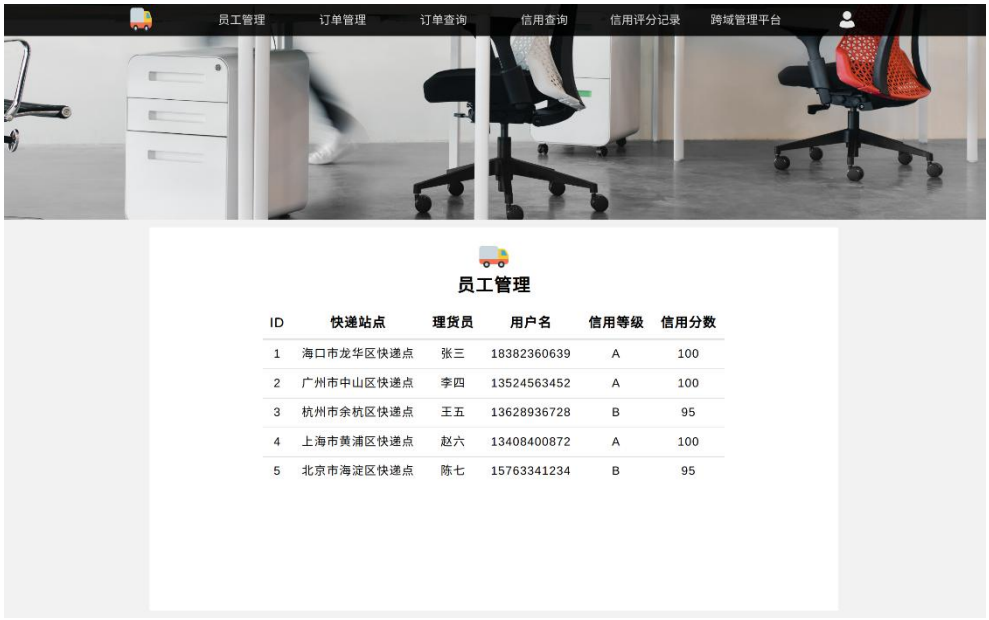


图 3.24 管理员员工管理

3. 订单管理

该页面如图 3.25 所示，管理员可以查看本系统处理过的所有订单，同时管理员可以在搜索框输入订单号选择相应的订单。

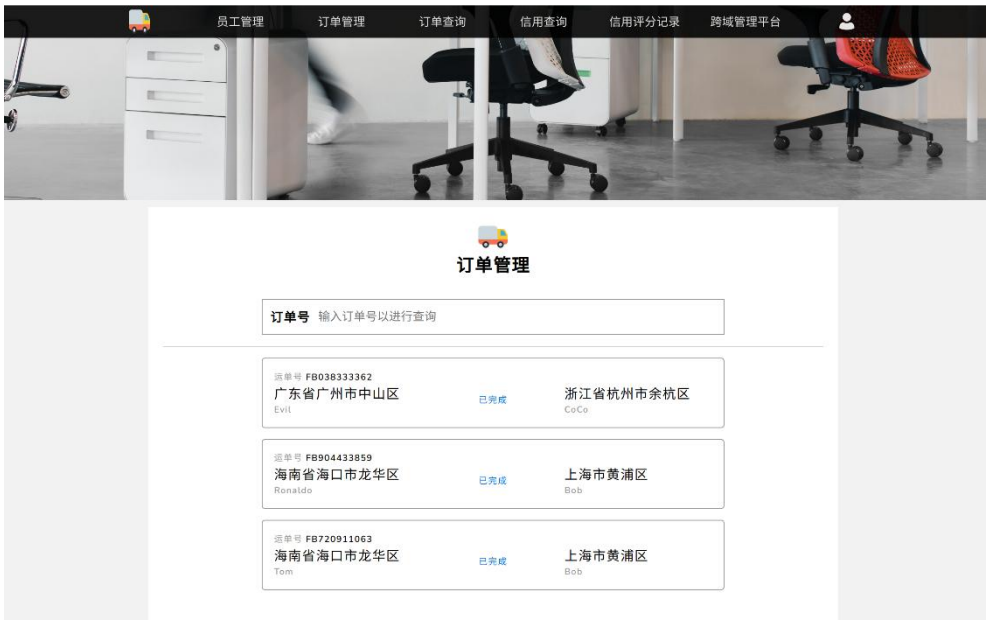


图 3.25 管理员订单管理

4. 订单查询

如图 3.26 所示，较于客户的订单查询页面，管理员除了可以查看包裹运送轨迹，

物流详情外，管理员还可以查看寄件人和收件人信息。此外，管理员可以点击区块链认证按钮进行摘要对比。

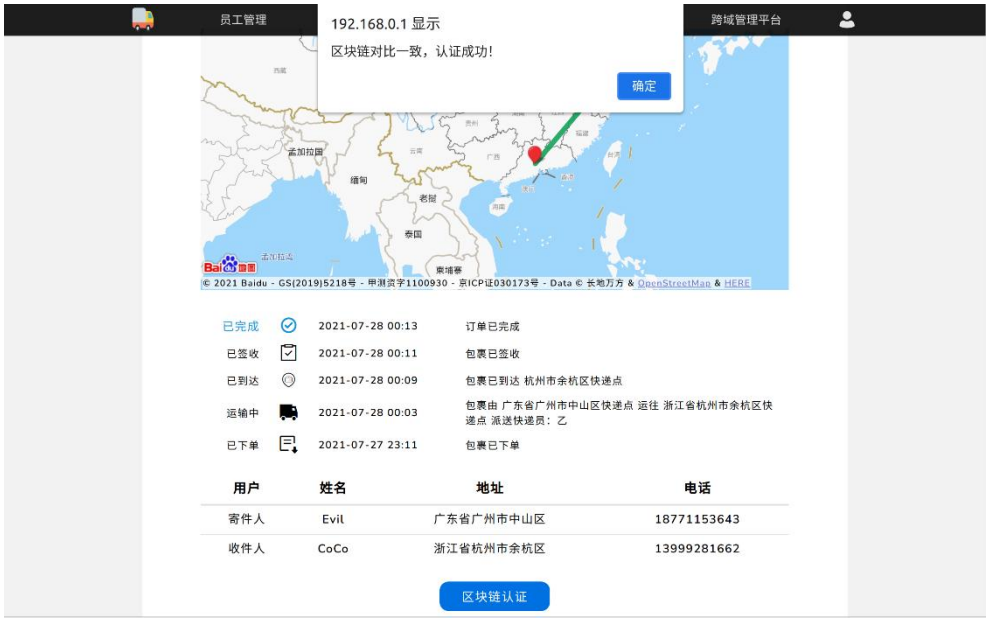


图 3.26 订单查询

5．信用查询

如图 3.27 所示，管理员可以在该界面查看目前的信用分数、等级和违规次数，同时了解评估规则。

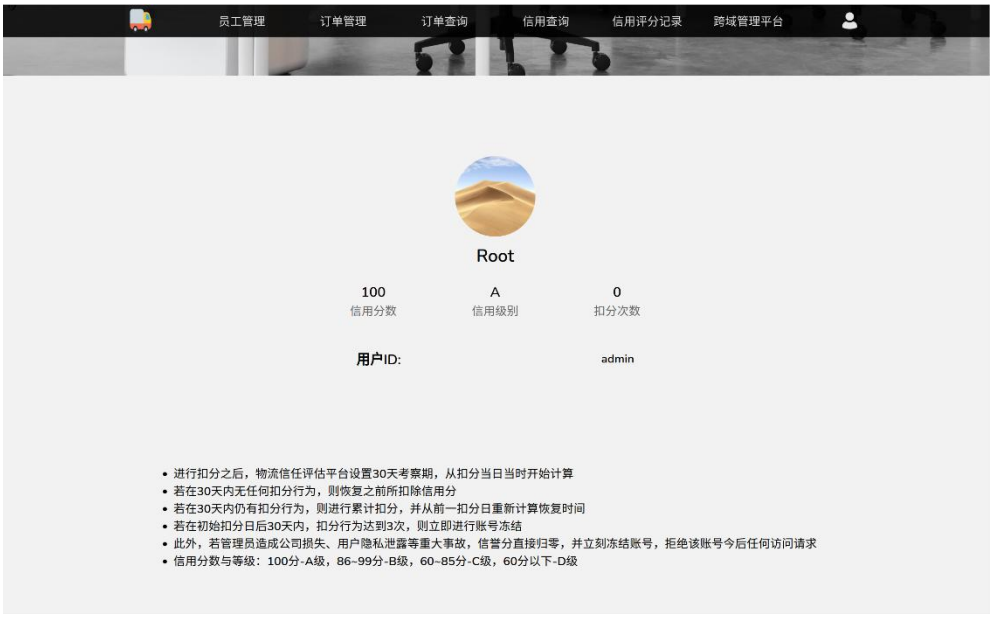


图 3.27 管理员信用查询

6．信用评分记录

如图 3.28 所示，管理员可以在该界面输入订单号查询该次订单交易全过程参与人

员的最终信用评分信息，并通过区块链认证按钮进行信用比对。

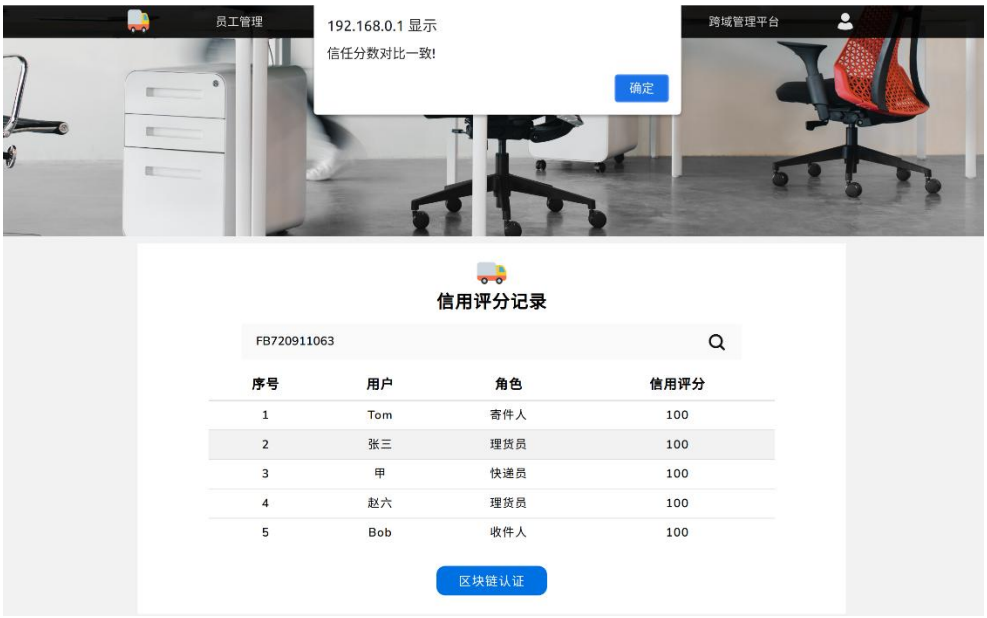


图 3.28 信用评分记录

（5）跨域测试

基于 WeCross，针对 FISCO BCOS 和 Fabric，开展了跨域测试，管理员可以点击导航栏上的跨域管理按钮进入，如图 3.29 所示。

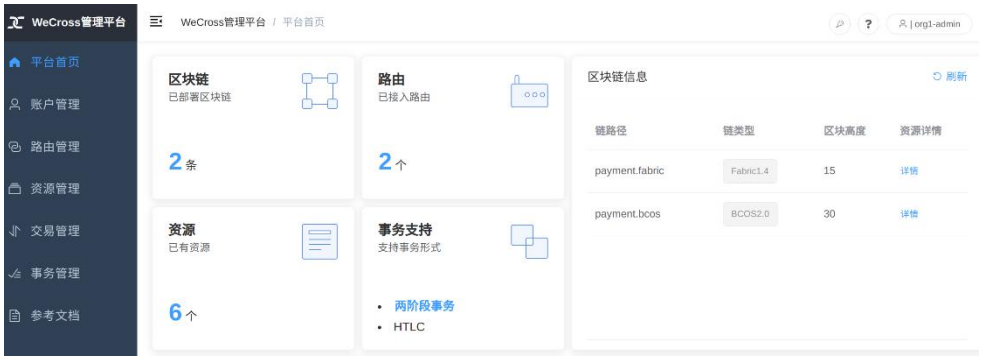


图 3.29 跨域管理

3.2.2 智能合约形式化测试

我们使用 Promela 建模语言和 SPIN 来对项目中使用的智能合约 TableTest1.sol 进行形式化测试。SPIN 是一个通用的形式化验证工具，可以验证分布式软件模型的正确性和并发系统逻辑一致性，以其简洁明了和自动化程度高而备受注目。SPIN 已成功应用在安全协议验证、控制系统验证、软件验证及最优化规划等领域。

项目中使用到的基本合约包括 FISCO BCOS 底层内置的数据库合约以及数据上链及查询交易的合约，我们选择后者进行形式化验证。合约代码如下：

```
pragma solidity>=0.4.24 <0.6.11;
pragma experimental ABIEncoderV2;

import "./Table.sol";
contract TableTest1 {
    event InsertResult(int256 count);

    TableFactory tableFactory;
    string constant TABLE_NAME = "t_test";
    constructor() public {
        tableFactory = TableFactory(0x1001); //The fixed address is 0x1001 for TableFactory
        tableFactory.createTable(TABLE_NAME, "Lid", "Abstract, Signature");
    }
    //insert records
    function insert(string memory Lid, string memory Abstract, string memory Signature)
    public
    returns (int256)
    {
        Table table = tableFactory.openTable(TABLE_NAME);

        Entry entry = table.newEntry();
        entry.set("Lid", Lid);
        entry.set("Abstract",Abstract);
        entry.set("Signature", Signature);
        int256 count = table.insert(Lid, entry);
        emit InsertResult(count);
        return count;
    }

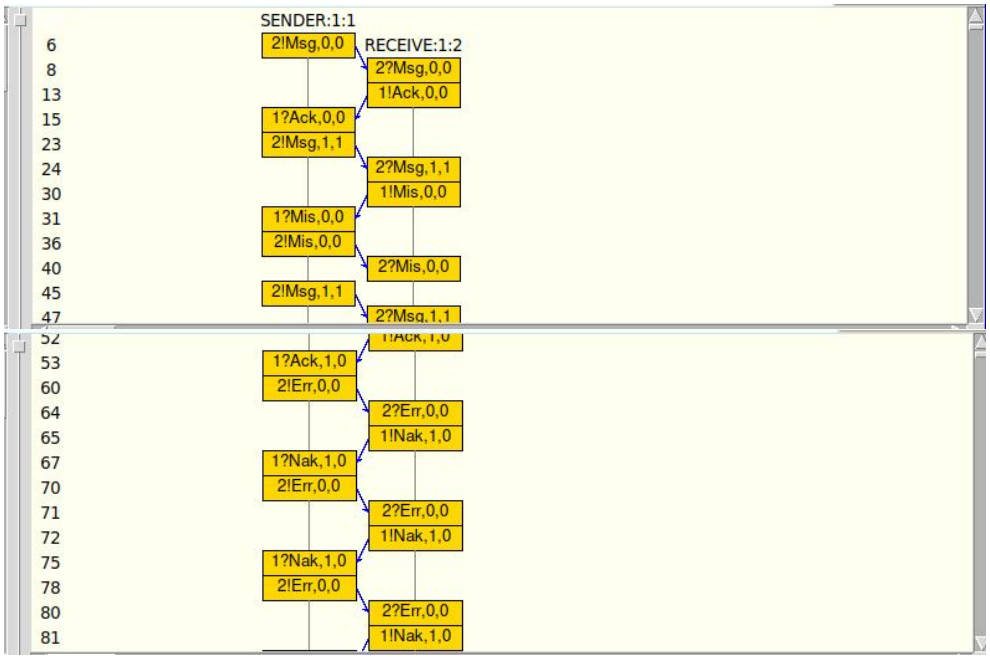
   //select records
    function select(string memory Lid)
    public
    view
    returns (string[] memory,string[] memory)
    {
        Table table = tableFactory.openTable(TABLE_NAME);
        Condition condition = table.newCondition();
        condition.EQ("Lid" , Lid);
        Entries entries = table.select(Lid, condition);
        string[] memory item_Abstract_list = new string[](
            uint256(entries.size())
        );
```

```
43.         string[] memory item_Signature_list = new string[](
44.             uint256(entries.size())
45.         );
46.         for (int256 i = 0; i < entries.size(); ++i) {
47.             Entry entry = entries.get(i);
48.             item_Abstract_list[uint256(i)] = entry.getString("Abstract");
49.             item_Signature_list[uint256(i)] = entry.getString("Signature");
50.         }
51.         return (item_Abstract_list,item_Signature_list);
52.     }
53. }
```

我们将其转换为 Promela 模型，并对其进行形式化测试。首先选择菜单项 Run->Set Simulation Parameters 设置模拟参数，用默认参数点击 start 开始，并点击 run 开始模拟，suspend 结束。然后进行一般性验证，无进展循环验证和人为加入错误验证，点击 Run->Set Verification Parameters，进行验证参数，并进行验证。

（1）时序图验证

时序图能直观展示模拟运行结果。在此仅给出运行过程中的时序图，说明模拟运行结果。对于其他运行结果，例如文本方式，经过分析，得到的结论与时序图完全一样。输出结果如图 3.30 所示，由时序图可知协议运行正确。



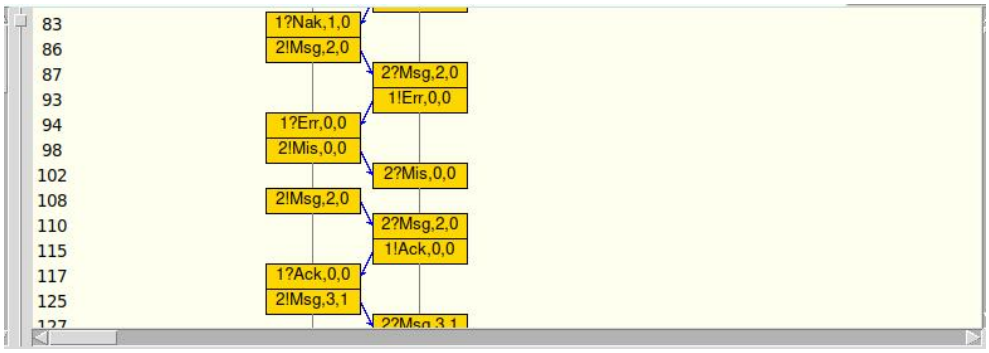


图 3.30 输出时序图样例

（2）一般性验证

在 SPIN 中，一般性验证就是选择打开 verification 界面，然后采取默认选项（穷举状态验证），即 safety，然后点击 run，开始进行一般性验证。由图 3.31 中可以看出，errors：0，说明无一般性验证错误。



图 3.31 一般性验证结果

通过对智能合约的建模和验证，SPIN 可以随机生成合约的所有状态，实验结果与合约的预期结果一致。

3.2.3 SDP 网络隐身功能测试

为了验证本作品 SDP 网络隐身模块的功能，我们使用 Nmap 端口扫描工具与 WireShark 抓包工具对该模块进行了测试，并通过 LOIC 工具对服务器进行了 DoS 攻击模拟，主要验证 SDP 管控平台能否使用网络隐身技术隐藏端口从而拒绝服务，以及客户端能否通过 Fwknop 进行认证从而访问 Web 服务。

验证效果如下：

1. 在客户端使用 LOIC 工具进行 DoS 攻击，输入服务器 IP 地址 172.16.1.1，并选择攻击方式为 HTTP，攻击端口为 80，速率开到最大（图 3.32），并使用 WireShark 进行抓包（图 3.33）。

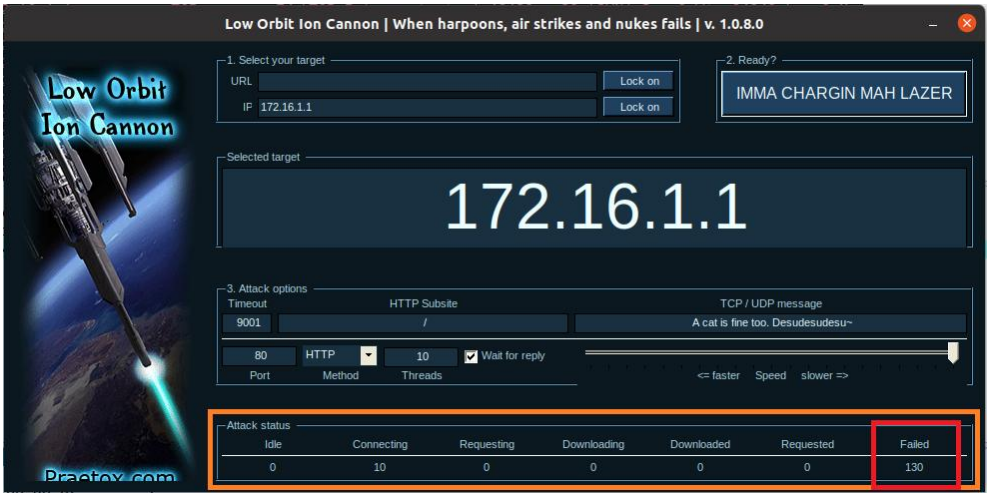


图 3. 32 DoS 攻击测试

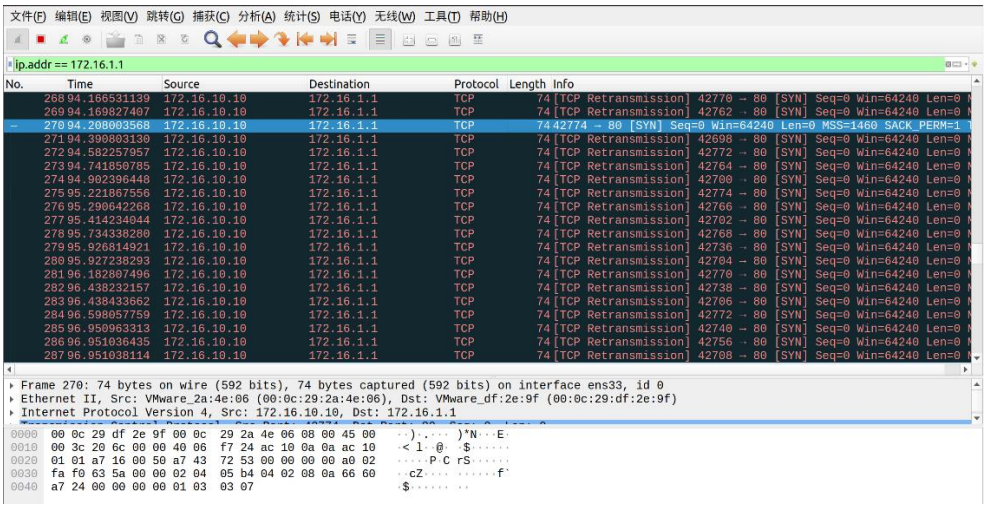


图 3. 33 DoS 抓包

通过图 3.32 和图 3.33 可以发现，攻击均失败。

2. 在客户端使用 Nmap 扫描端口，发现端口 80 被过滤（图 3.34）。

```
root@ubuntu:/home/eilo# nmap 172.16.1.1 -p80
Starting Nmap 7.80 ( https://nmap.org ) at 2021-07-19 22:48 PDT
Nmap scan report for bogon (172.16.1.1)
Host is up (0.00045s latency).

PORT   STATE    SERVICE
80/tcp filtered http
MAC Address: 00:0C:29:F8:86:D0 (VMware)
```

图 3.34 第一次 Nmap 扫描结果

3. SDP 客户端进行认证，同时使用 WireShark 进行抓包分析（图 3.35），可见客户端向控制平台 62201 端口发送 UDP 认证流量，同时可见认证所用的 Packet data 采用密文形式。同时由于 HMAC 算法的使用，每次发送的 SPA 包都是不一样的，从而

抵御重放攻击。

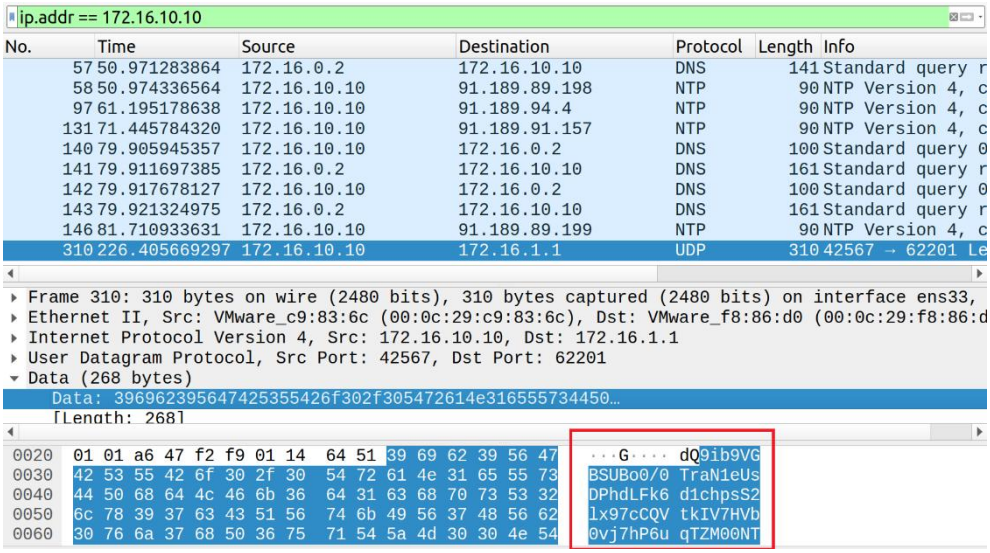


图 3.35 Fwknop 认证数据包抓包分析

4. 再次在客户端使用 Nmap 进行端口扫描，确认此时 80 端口已开放（图 3.36）。通过查看此时防火墙策略可知此时 Fwknop 创建了四条防火墙规则（为四个端口配置 Fwknop 服务，分别为 SSH、HTTP、HTTPS、OpenVPN，验证将会暂时开放所有端口），允许来自 Fwknop 客户端的 IP 连接 80 端口（若未建立链接，该端口会在 30s 之后再次关闭）。

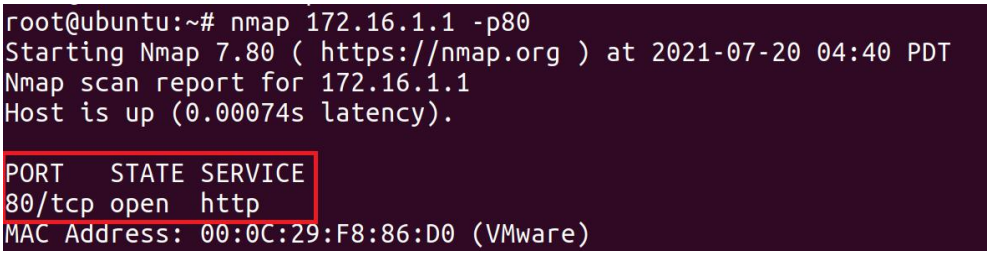


图 3.36 第二次 Nmap 扫描结果

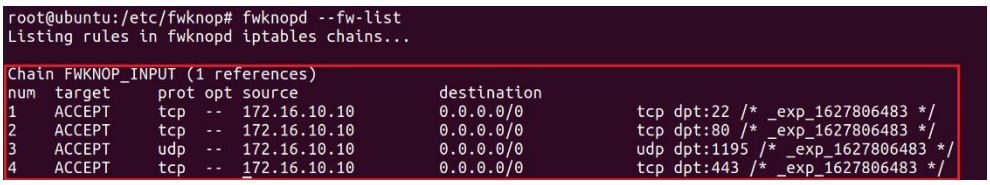


图 3.37 添加四条防火墙规则

3.3 性能测试

3.3.1 系统性能测试

为了测试与优化系统的性能，我们使用 LoadRunner 对项目进行了测试，并从多方面分析测试结果。

（1）测试工具

LoadRunner 是一个预测系统行为和性能的负载测试工具。通过模拟虚拟用户实施并发负载及实时性能监测的方式来确认和查找系统性能瓶颈，其适用于各种体系架构，能支持广泛的协议和技术，为测试提供特殊的解决方案。

（2）测试描述

本次测试的要求验证在 30 分钟内完成 2000 次用户登录系统，然后进行寄件、指定快递员、货物交接等基本物流业务，最后退出。

（3）性能指标

表 3.3 性能指标

测试项	目标值
平均事务响应时间	<= 3 秒
TPS	>= 200
错误率	= 0%
CPU 利用率	< 70%
内存利用率	< 75%
物理磁盘利用率	< 70%
网络吞吐量	< 60%

（4）测试结果及分析

1. 结果摘要

LoadRunner 进行场景测试结果收集后，首先显示该结果的一个摘要信息，如图 3.38 所示。概要中列出了“Statistics Summary（统计信息摘要）”、“Transaction Summary”以及“HTTP Responses Summary（HTTP 响应摘要）”等。以简要的信息列出本次测试结果。

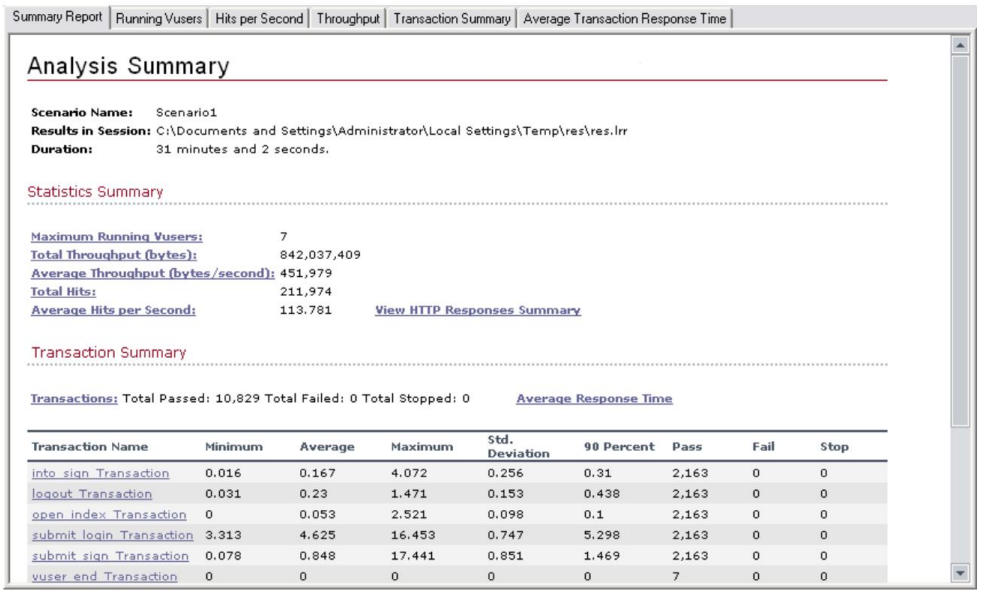


图 3.38 性能测试结果摘要

2. 统计摘要信息

该部分给出了场景执行结束后并发数、总吞吐量、平均每秒吞吐量、总请求数、平均每秒请求数的统计值，如图 3.39 所示。

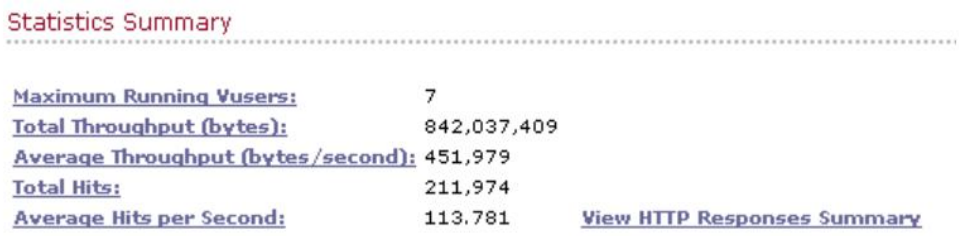


图 3.39 统计结果摘要

从该图我们得知，本次测试运行的最大并发数为 7，总吞吐量为 842,037,409 字节，平均每秒的吞吐量为 451,979 字节，总的请求数为 211,974，平均每秒的请求为 113.781。

3. 事务摘要

该部分给出了场景执行结束后相关 Action 的平均响应时间、通过率等情况，如图 3.40 所示。从该图我们得到每个 Action 的平均响应时间与业务成功率。

Transaction Summary

Transactions: Total Passed: 10,829 Total Failed: 0 Total Stopped: 0 Average Response Time

Transaction Name	Minimum	Average	Maximum	Std. Deviation	90 Percent	Pass	Fail	Stop
into_sign_Transaction	0.016	0.167	4.072	0.256	0.31	2,163	0	0
logout_Transaction	0.031	0.23	1.471	0.153	0.438	2,163	0	0
open_index_Transaction	0	0.053	2.521	0.098	0.1	2,163	0	0
submit_login_Transaction	3.313	4.625	16.453	0.747	5.298	2,163	0	0
submit_sign_Transaction	0.078	0.848	17.441	0.851	1.469	2,163	0	0
vuser_end_Transaction	0	0	0	0	0	7	0	0
vuser_init_Transaction	0	0	0.001	0	0.001	7	0	0

图 3.40 事务摘要

4. HTTP 响应摘要

从图 3.41 中可以看到，在本次场景测试过程中 LoadRunner 共模拟发出了 211974 次请求（与“统计信息摘要”中的“Total Hits”一致），其中“HTTP 200”的是 209811 次，而“HTTP 404”则有 2163 次，说明在本次过程中，经过发出的请求大部分都能正确响应了，但还是有部分失败了，但未影响测试结果。

HTTP Responses Summary

HTTP Responses	Total	Per second
HTTP_200	209,811	112.62
HTTP_404	2,163	1.161

图 3.41 HTTP 响应摘要

5. 并发数分析

“Running Vusers（运行的并发数）”显示了在场景执行过程中并发数的执行情况。它们显示 Vuser 的状态、完成脚本的 Vuser 的数量以及集合统计信息。图 3.42 显示了在性能测试过程中 Vusers 运行情况，从图中我们可以看到，Vusers 的运行趋势与执行计划中的设置一致，表明 Vusers 按照预期设置运行，没有出现运行错误。

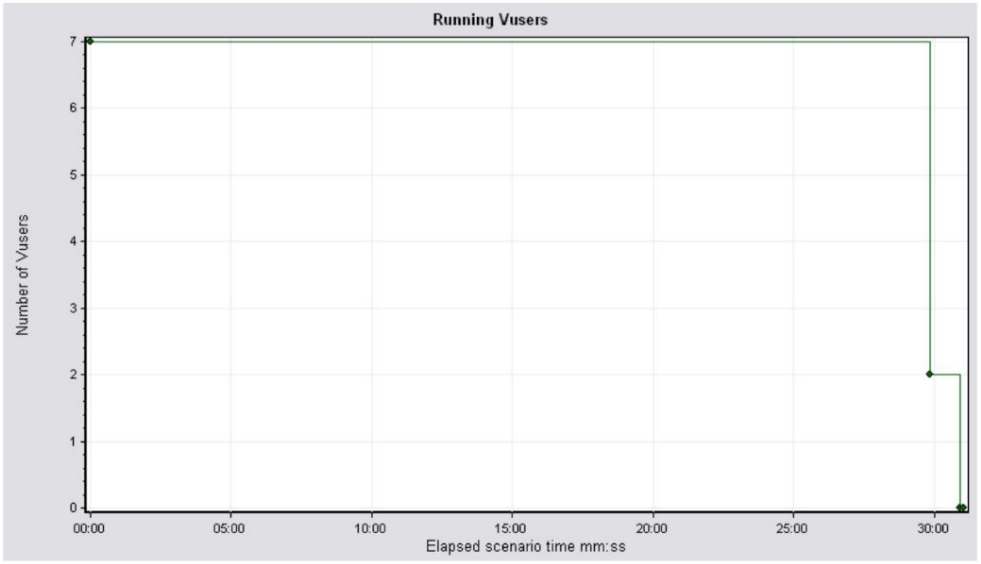
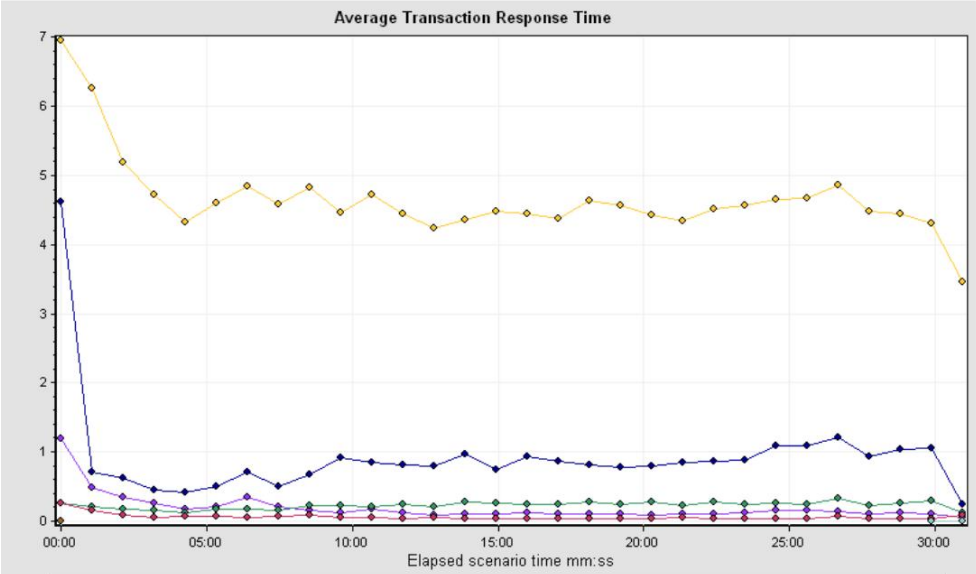


图 3.42 运行的并发数

6. 响应时间



Transaction Name	Minimum	Average	Maximum	Std. Deviation	90 Percent	Pass	Fail	Stop
into_sign_Transaction	0.016	0.167	4.072	0.256	0.31	2,163	0	0
logout_Transaction	0.031	0.23	1.471	0.153	0.438	2,163	0	0
open_index_Transaction	0	0.053	2.521	0.098	0.1	2,163	0	0
submit_login_Transaction	3.313	4.625	16.453	0.747	5.298	2,163	0	0
submit_sign_Transaction	0.078	0.848	17.441	0.851	1.469	2,163	0	0
vuser_end_Transaction	0	0	0	0	0	7	0	0
vuser_init_Transaction	0	0	0.001	0	0.001	7	0	0

图 3.43 平均事务响应时间

7. 每秒点击数

“Hits per Second（每秒点击数）”反映了客户端每秒钟向服务器端提交的请求数量。图 3.44 显示的是“Hits per Second”与“Average Throughput (bytes/second)”的复合图，从图中可以看出，两种图形的曲线都正常并且基本一致，说明服务器能及时的接受客户端的请求，并能够返回结果。

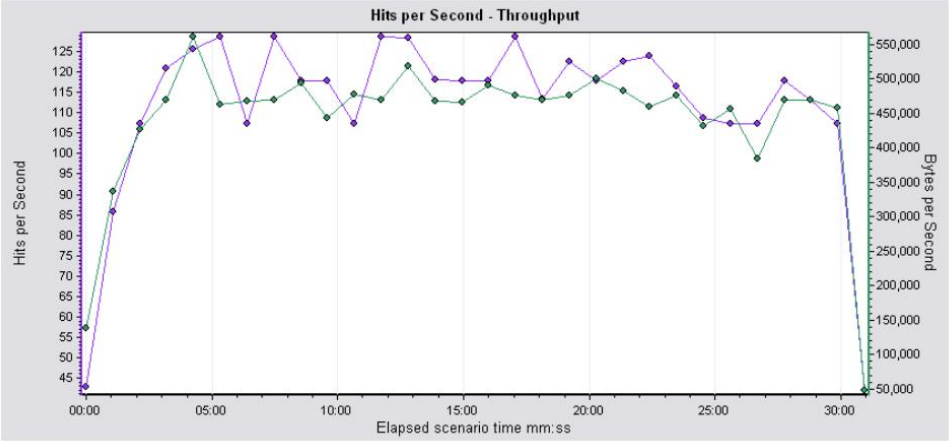


图 3.44 每秒点击数与每秒吞吐量复合

8. 业务成功率

从下图 3.45 中可以看出，所有的 Aciton 都是绿色，即表示为 Passed，同时除了 vuser_init 与 vuser_end 两个事务，其他的事务通过数为 2163，也就表明在 30 分钟的时间里，共完成了 2163 次业务操作。那么根据这些可以判断本次测试业务的成功率是 100%。

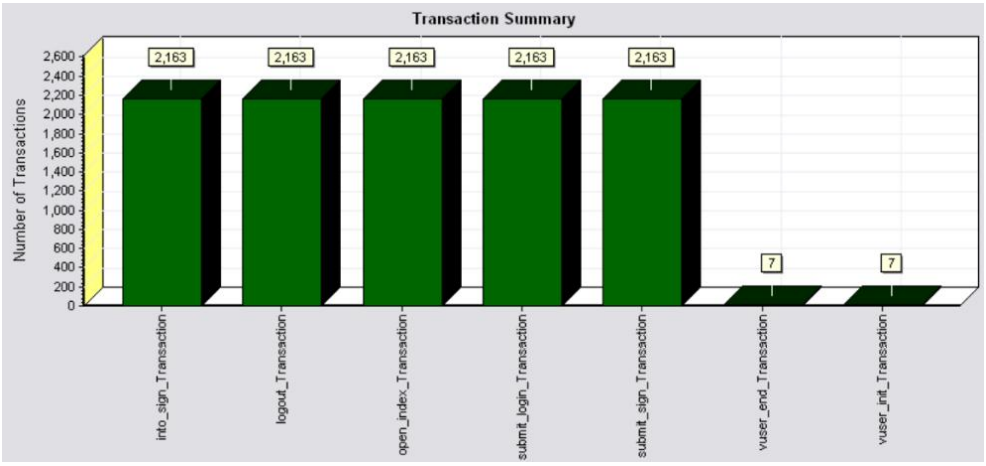


图 3.45 业务状态统计

9. 系统资源

系统资源图显示了在场景执行过程中被监控的机器系统资源使用情况，一般情况下监控机器的 CPU、内存、网络、磁盘等各个方面。本次测试监控的是测试服务器的 CPU 使用率与内存使用率，以及处理器队列长度，具体的数据如下图 3.46 所示：

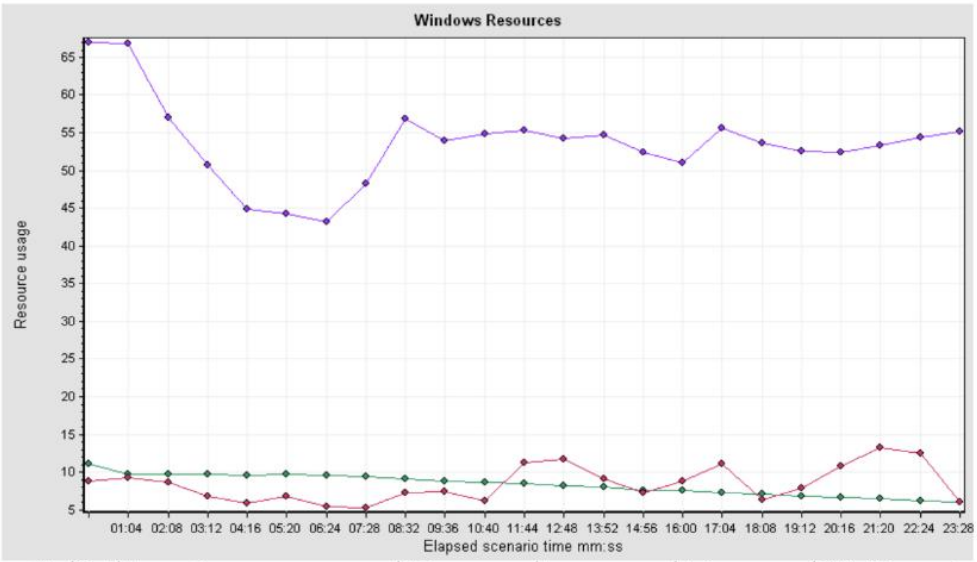


图 3.46 测试服务器系统资源监控结果

从图中可以看出，CPU 使用率、可用物理内存、CPU 的队列长度三个指标的曲线均较为平滑，三者的平均值分别为：53.582%、2383.456M、8.45，而测试服务器总的物理内存为 8192MB，那么内存使用率为（8192-2383.456）/8192=70.91%。

（5）测试结论

获得上述数据后，最新的测试结果记录如表 3.4 所示。

表 3.4 测试结果

测试项	目标值	实际值	是否通过
平均事务响应时间	<= 3 秒	2.298	Y
业务成功率	100%	100%	Y
TPS	>=200	217	Y
业务总数	2000(30 min)	2163	Y
CPU 使用率	<75%	53.582%	Y
内存使用率	<70%	70.91%	Y
物理磁盘利用率	<70%	63.32%	Y
网络吞吐量	<60%	57.92%	Y

本次测试运行的最大并发数为 237，总吞吐量为 842,037,409 字节，平均每秒的吞吐量为 451,979 字节，总的请求数为 211,974，平均每秒的请求为 113.781。从上表数据来看，本次测试总体上已经达到了预期的性能指标，证明了该系统能够承载日常的并发数和并发量，但从其他的数据，比如 CPU 的队列长度、内存使用率来看，Web 服务器的硬件资源需要提升。

3.3.2 区块链性能测试

我们使用 Hyperledger Cailper 2.0 对项目中的区块链模块进行了性能测试，并对结果进行分析，详细过程描述如下。

（1）测试工具

Caliper 是一个开源的通用区块链性能测试工具。同时，Hyperledger 项目下设了性能及可扩展性工作组（PWSG），专门负责对各种性能指标（TPS、延迟、资源利用率等）进行形式化、规范化的定义，Caliper 在设计也采用这一套性能指标体系并内嵌进了框架中。Caliper 能够方便地对接多种区块链平台并屏蔽了底层细节，用户只需要

负责设计具体的测试流程，即可获取 Caliper 输出的可视化性能测试报告。可见拥有这些特点的 Caliper，能恰好满足项目中区块链部分对压测工具的需求。

（2）测试过程

准备阶段：在此阶段，Master 进程使用区块链配置文件创建并初始化内部区块链对象，按照配置中指定的参数部署智能合约，并启动监控对象以监控后端区块链系统的资源消耗。

测试阶段：在此阶段，Master 进程根据配置文件执行测试，将根据定义的负载生成任务并将其分配给客户端子进程。最后将存储各个客户端返回的性能统计信息以供后续分析。

报告阶段：分析每个测试轮次的所有 Client 进程的统计数据，并自动生成报告。图 3.47 和图 3.48 分别展示了测试的统计结果与 HTML 格式报告。

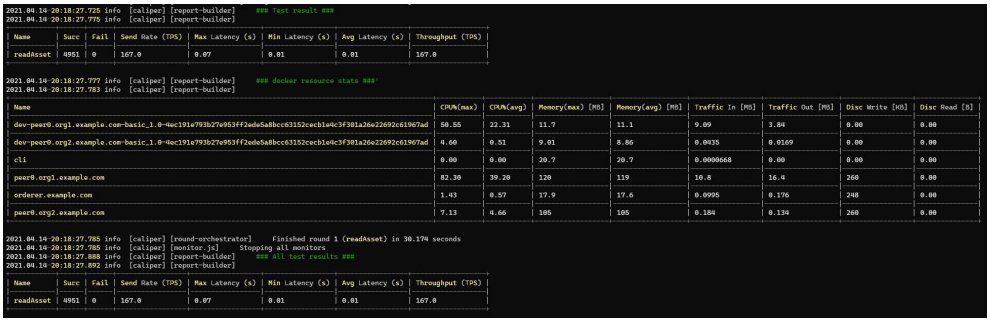


图 3.47 区块链测试统计结果

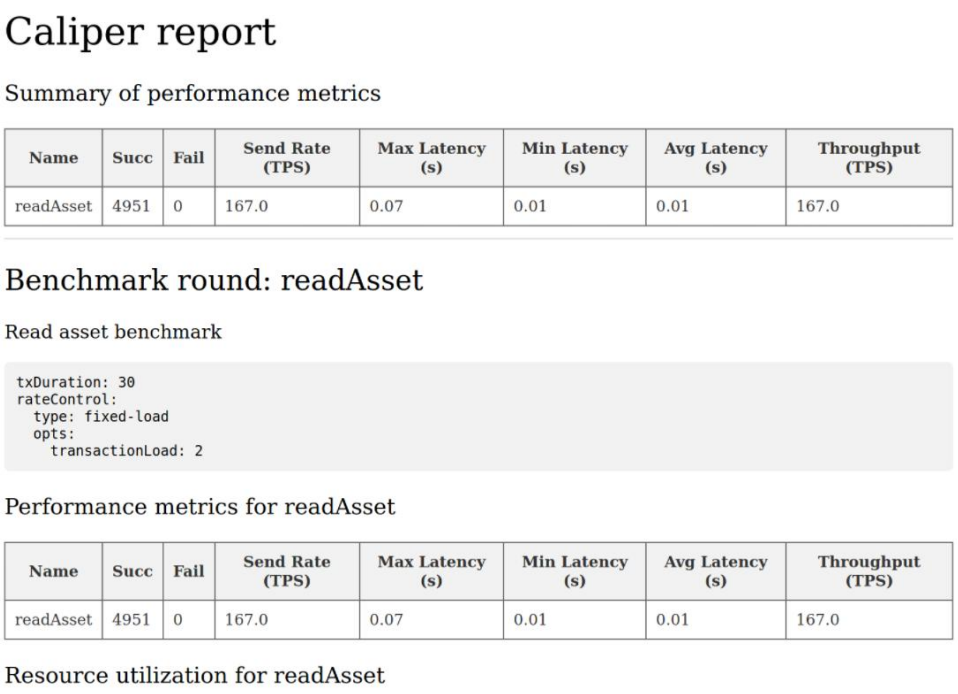


图 3.48 区块链测试 HTML 格式报告

（3）结果分析

目前，区块链性能指标还没有完备的国家标准，相关部门正在积极制定。根据现有的区块链行业标准（表3.5），我们系统中的区块链模块性能基本符合要求，主要性能瓶颈在于区块链服务器配置。

表3.5 现有区块链行业标准

规则项	要求
压力测试	每秒交易接收量与上链量基本一致，上链成功率高于95%
性能指标	上链成功率（＞95%）
	TPS(＞200)
	平均延迟时间（＜0.5s）
	延迟（＜1000ms）

3.4 安全性分析

（1）保密性

用户发送单包授权网络协议（SPA）进行认证时，单个携带认证信息的 UDP 数据包使用 AES 算法进行对称加密，同时利用嵌入 SHA-256 的 HMAC 加密算法保障数据传输的完整性以及抗重放攻击。此外，所有数据将在客户端在与服务器建立的双向加密 TLS 连接通道中进行传输，有效保证用户数据安全。

（2）可认证性

用户在发起业务访问请求时，多因子认证平台采用静、动态因子结合认证的方式，对用户采集的多源信息数据（用户身份，设备环境，动态行为）进行检验认证，解决了单因子认证强度较弱，易导致数据泄露等问题。

（3）抗攻击性

默认情况下，隐身安全网关拒绝所有的连接请求，只有管控平台下发认证策略后，才动态接受指定客户端的连接，并通过分离访问控制和数据信道来保护关键资产和基础架构，使其中的每一个都看起来是“隐身”的，从而阻止潜在的基于网络的攻击。此外，隐藏的 iptables 能有效防御 DDoS 等攻击。

（4）完整性

物流过程中的中转交易信息，用户的信用评分将以特定的数据格式上传至区块链。

区块链网络中的参与组织通过统一的共识机制与算法可以自动化地更新分布式账本，且不存在第三方地中心化机构来参与，同时利用密码学的相关原理进行数据验证，运用多私钥进行访问权限控制。保证了用户数据的安全性与不可篡改性。

第四章 创新性说明

新一代信息技术与实体经济深度融合，产业数字化为物流业带来了新的生产力，但同时也带来了新的安全挑战。近年来，物流业信息安全问题频发。如何有效保证用户隐私，引起了国家和物流企业的高度重视。传统的物流系统一般采用基于边界的网络安全架构。随着网络安全边界逐渐瓦解，内外部威胁愈演愈烈，传统的边界网络安全架构已难以应付。基于国产密码的零信任物流服务平台通过国密算法、零信任安全、区块链等多种技术，以身份为中心重新构建网络安全新的边界，持续校验并严格控制数据访问权限，实现了交易信息的溯源和交易各方的不可否认，有效保护了用户隐私。

（1） 提高了物流货物的定位精度

本作品利用北斗卫星定位系统，实现了货物位置的实时查询和运送轨迹的查看。相较于传统的定位应用，基于北斗的高精度定位模块可以显著提高定位和授时精度，且定位精度分布均匀、实时性好、可靠性高。

（2） 保护了用户信息的隐私性

本作品基于国密算法根据零信任安全理念，采用 SDP 架构进行设计，对用户进行持续的身份验证和动态评估，只有通过验证才允许访问企业应用服务器。同时所有数据请求均在双向加密隧道中进行传输，有效保护用户隐私信息。

（3） 保障了隐私数据的存储安全

本作品利用国产联盟链 FISCO BCOS 作为底层框架，并进行国密化改造。物流过程中的每一次交易都会被完整记录并备份在各个服务器节点中，利用区块链去中心化、可追溯、防篡改等特性，保证数据的存储安全，实现交易的溯源和交易各方的不可否认，有效解决包裹纠纷问题。此外，跨域管理的应用加强了数据间的流通性。

（4） 实现了物流系统的自主可控

本作品提出基于国产密码的零信任物流服务平台方案，以国密算法为主体，基于零信任安全理念采用 SDP 架构进行设计，使用国产联盟链 FISCO BCOS 作为底层框架，同时融入北斗高精度定位系统。该方案符合我国自主可信安全的发展需求，适应物流业数字化转型需求的新一代安全体系，探索区块链服务平台在物流领域的应用，助力北斗的民用推广。

第五章 总结

物流是构建互联网经济的重要基础，随着数字化、智能化的推进，物流行业的发展速度越来越快。但是，目前物流业存在网络安全边界瓦解、信息不对称、缺乏信任、信息安全漏洞较多等问题。对此，本文针对我国物流快递业当前频发的信息安全问题，以国密算法为主体，以身份为中心构建新的网络安全边界，同时根据物流快递业的实体网络结构对区块链节点网络进行重构。基于国产密码的零信任物流服务平台作为物流领域创新的一体化综合型区块链数字服务平台，利用国密算法、零信任安全架构、区块链技术、北斗卫星定位系统等高新技术，保障数据安全和隐私保护，为广大用户提供了优质服务，增强了物流体系的信息化、数字化和智能化水平。

下一步工作：

（1）完善目前功能，加强各组件连接稳定性。

（2）加强系统安全防护，优化SDP架构和相关算法。

（3）优化区块链性能和稳定性。

（4）推出小程序、APP等移动端应用，便捷用户使用。

参考文献

[1] 北商研究院.2020 物流行业白皮书[R],2020.

[2] 中国电子技术标准化研究院.物流快递行业信息安全研究(2018)[R],2019.

[3] 冯毅.基于区块链的智能物流系统的研究与实现[D].电子科技大学,2019.

[4] 王子岳.面向供应链溯源的区块链系统研究与优化[D].北京交通大学,2019.

[5] 杨洵. 基于国密算法的区块链架构研究[D].北方工业大学,2020.

[6] 李翔宇. 基于国密算法的区块链及 UTXO 模型优化研究[D].云南大学,2019.

[7] 奚宇航.基于国密算法的即时通讯系统的设计与实现[D].广西师范大学,2020.

[8] 张盛仕.基于国密算法加密技术的 SoC 设计与优化[D].广东工业大学,2019.

[9] 唐泽严.基于门限的移动终端安全密钥分发机制的研究及应用[D].西南科技大学,2019.

[10] 郑欣.基于国密算法的加解密和签名验签系统设计及其实现[D].广东工业大学,2018.

[11] 毛宇.移动网络支付中的国密算法研究[D].哈尔滨理工大学,2018.

[12] 杨洵.基于国密算法的区块链架构研究[D].北方工业大学,2020.

[13] 李翔宇.基于国密算法的区块链及 UTXO 模型优化研究[D].云南大学,2019.

[14] 谢宗晓,董坤祥,甄杰.国产商用密码算法及其相关标准介绍[J].中国质量与标准导报,2020(06):12-14+23.

[15] Tijan E, Aksentijević S, Ivanić K, et al. Blockchain technology implementation in logistics[J]. Sustainability, 2019, 11(4): 1185.

[16] Perboli G, Musso S, Rosano M. Blockchain in logistics and supply chain: A lean approach for designing real-world use cases[J]. Ieee Access, 2018, 6: 62018-62028.

[17] Issaoui Y, Khiat A, Bahnasse A, et al. Smart logistics: Study of the application of blockchain technology[J]. Procedia Computer Science, 2019, 160: 266-271.

[18] 蔡陈玉.基于北斗的船舶监控系统设计与开发[D].上海海洋大学,2018.

[19] 蔡亚军.基于北斗卫星通信的船舶位置公共服务平台研发[D].集美大学,2018.

[20] 肖挽强.基于北斗通信的海运液态危险品远程监测系统研究[D].集美大学,2018.

[21] 高启.基于属性加密的物流信息隐私保护方案[D].西安电子科技大学,2019.

[22] 张克落.物流用户隐私数据保护和访问权限管理研究[D].东南大学,2018.

[23] Gao Q, Zhang J, Ma J, et al. LIP-PA: A logistics information privacy protection scheme with position and attribute-based access control on mobile devices[J]. Wireless Communications and Mobile Computing, 2018.

[24] 微众银行区块链团队.WeCross 技术白皮书[R],2020.

[25] Mohan C. State of public and private blockchains: Myths and reality[C]//Proceedings of the 2019 International Conference on Management of Data. 2019: 404-411.

[26] Wang Y, Wang C, Luo X, et al. A blockchain-based IoT data management system for secure and scalable data sharing[C]//International Conference on Network and System Security. Springer, Cham, 2019: 167-184.

[27] 潘吴斌,任国强.软件定义边界 SDP:概念、技术及应用研究综述[J].数字通信世界,2021(03):192-195.

[28] 于欣越,孙刚,张亚伟.基于零信任的软件定义边界网络隐身技术研究[J].通信技术,2021,54(05):1229-1234.

[29] 张泽洲.新 IT 环境下的零信任安全架构[J].网络安全和信息化,2021(02):50-51.

[30] Papakonstantinou Nikolaos,Van Bossuyt Douglas L.,Linnosmaa Joonas,Hale Britta,O'Halloran Bryan. A Zero Trust Hybrid Security and Safety Risk Analysis Method[J]. J. Comput. Inf. Sci. Eng,2021.

[31] 秦益飞,张英涛,张晓东.零信任落地路径研究[J].信息安全与通信保密,2021(01):84-91.

[32] Collier Zachary A.,Sarkis Joseph. The zero trust supply chain: Managing supply chain risk in the absence of trust[J]. International Journal of Production Research,2021,59(11).

[33] 章岐贵,黄海,汪有杰.基于零信任的软件定义边界安全模型研究[J].信息技术与信息化,2020(11):92-94.

[34] 王斯梁,冯暄,蔡友保,陈翼.零信任安全模型解析及应用研究[J].信息安全研究,2020,6(11):966-971.

[35] 蔺旭冉,毛天宇.零信任安全架构技术研究和应用思考[J].中国核电,2020,13(05):582-586.